Gouvernance, Normes & Standard

Un cours de Yann Fornier

Pourquoi ce cours ?

Objectif : Comprendre l'écosystème informatique et les normes qui lui sont appliquées.

Orientation stratégique et législative des systèmes informatiques

Les plus grosses amendes reçues pour non respect des réglementations :

Meta : 2023 - Par l'autorité de contrôle irlandaise : 2,5 milliards d'euros pour un transfert de données de l'UE vers les USA

Janvier 2023 : Meta - 390 millions d'euros - utilisation de données personnelles dans le cadre de contacts publicitaires

Amazon : 2021 746 millions d'euros

Google : 2021 - 90 millions d'euros et 60 millions d'euros

Sommaire - Déroulé

6 cours de 1h30

Cours 1	Cours 2	Cours 3	Cours 4	Cours 5	Cours 6
Introduction aux gouvernances, aux normes et aux standards	**Normes et standards informatiques**	**Gouvernance informatique** **Lois et réglementations**	**Normes pour la Confidentialité et la Sécurité**	**Normes pour la gestion des risques**	**Conception de Systèmes conformes aux normes**

Notation : **Etudes de cas**



Sommaire

Cours 1: Introduction aux Gouvernances, Normes et Standards

Définitions et concepts de base

Qu'est ce que la gouvernance informatique ?

Qu'est ce qu'un standard ?

Qu'est ce qu'une norme ?

Principaux acteurs et organismes de normalisation

Etude de cas - *Fonctionnement d'un organisme de normalisation*

Sommaire

Cours 2: Normes et Standards Informatiques

ISO 27001 pour la sécurité de l'information

ITIL pour la gestion des services informatiques

ISO 9001 pour la gestion de la qualité

PCI DSS pour la sécurité des paiements par carte

Sommaire

Cours 3: Gouvernance Informatique

COBIT comme cadre de gouvernance informatique

Rôles et responsabilités des parties prenantes

Mise en œuvre de la gouvernance informatique

Sommaire

Cours 4: Normes pour la Confidentialité et la Sécurité

RGPD (Règlement général sur la protection des données)

NIST Cybersecurity Framework

HIPAA (Health Insurance Portability and Accountability Act)

Sommaire

Cours 5: Normes pour la Gestion des Risques

ISO 31000 pour la gestion des risques

COSO ERM (Enterprise Risk Management)

Méthodologies de gestion des risques en informatique

Sommaire

Cours 6: Conception de Systèmes Conformes aux Normes

Intégration des normes dès la phase de conception

Validation et vérification de la conformité

Documentation et rapports de conformité

Cours 1 : Introduction aux Gouvernances, Normes et Standards

Définitions et concepts de base

Qu'est ce que la gouvernance informatique ?

La **gouvernance informatique**, les **normes** et les **standards** forment le socle sur lequel repose la **fiabilité**, la **sécurité** et la **conformité** des systèmes informatiques modernes.



Définitions et concepts de base

Qu'est ce que la gouvernance informatique ?

La **gouvernance informatique** se réfère à l'ensemble des **règles**, des **processus** et des **pratiques** qui guident la manière dont une organisation utilise ses ressources informatiques pour atteindre ses **objectifs stratégiques**. Cela inclut la **prise de décisions**, la **gestion des risques**, la conformité aux **normes** et la **supervision** des opérations informatiques.

Nous étudierons la gouvernance dans le cours 3 "La Gouvernance Informatique"



Définitions et concepts de base

Qu'est ce qu'une norme?

Les **normes** sont des **spécifications techniques** qui définissent les exigences minimales à respecter pour garantir la **qualité**, la **compatibilité** et la **sécurité** des produits, des services ou des systèmes informatiques. Elles sont élaborées par des organismes de normalisation pour standardiser les pratiques et faciliter l'interopérabilité.

IEEE
Advancing Technology for Humanity

AGENCE NATIONALE DE LA SÉCURITÉ DES SYSTÈMES D'INFORMATION
ANSSI

ISO
International Organization for Standardization

IEC
International Electrotechnical Commission

ITU

Définitions et concepts de base

Il existe 3 grands types de normes “primaires”

Produits

Production du consommateur & Interopérabilité

Services

Seuil minimum de qualité de prestation

Processus

Production & Distribution de services et produits

Il existe également d’autres normes “secondaires”

Formelles

Informelles

Propriétaires

Accessibilité

Compatibilité

Sécurité

etc…

Définitions et concepts de base

Les **standards**, souvent utilisés de manière interchangeable avec le terme "normes", désignent des **critères de référence** acceptés par **l'industrie** ou la **communauté** pour évaluer la **conformité**, la **performance** ou la **sécurité**. Les standards peuvent être internes à une organisation ou définis par des organismes externes.





Principaux organismes de Normalisation

Les organismes de normalisation jouent un rôle central dans le développement et la maintenance des normes et des standards en informatique.













L’ISO : International Organization for Standardization

ISO (Organisation internationale de normalisation) :

L'ISO est une organisation internationale qui élabore des normes mondialement reconnues dans divers domaines, y compris la sécurité de l'information (ISO 27001), la gestion de la qualité (ISO 9001) et d'autres domaines liés à l'informatique.

ISO 27001	ISO 9001	ISO 45001
Sécurité de l’information	*Gestion de la qualité*	*SST*

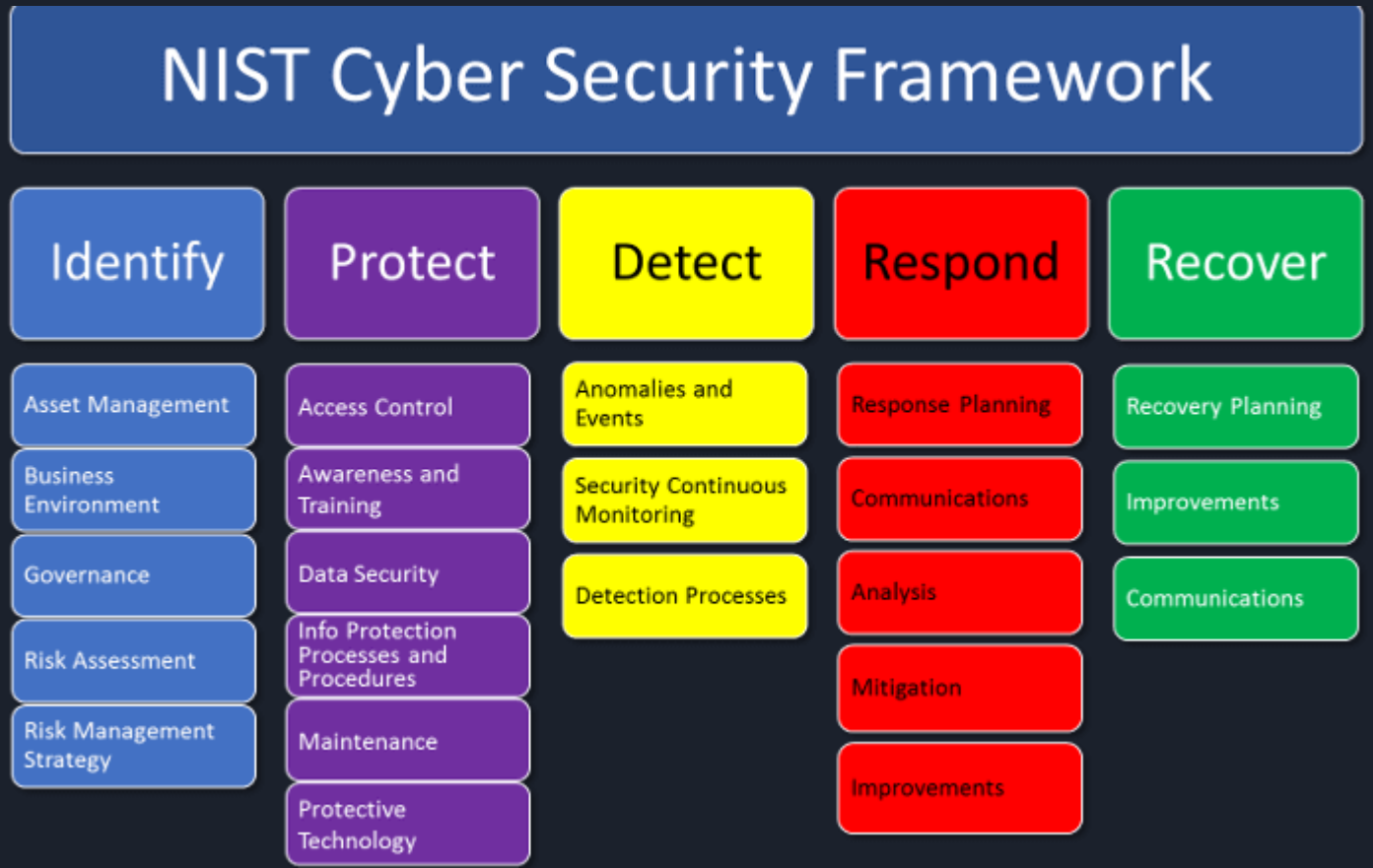
The NIST : National Institute of Standards and Technology

NIST (Institut national des normes et de la technologie) :

Le NIST est une agence gouvernementale des États-Unis qui développe des normes et des lignes directrices en matière de cybersécurité, de cryptographie et d'autres domaines liés à la technologie.



NIST


NIST Cyber Security Framework
Identify
Asset Management
Business Environment
Governance
Risk Assessment
Risk Management Strategy
Protect
Access Control
Awareness and Training
Data Security
Info Protection Processes and Procedures
Maintenance
Protective Technology
Detect
Anomalies and Events
Security Continuous Monitoring
Detection Processes
Respond
Response Planning
Communications
Analysis
Mitigation
Improvements
Recover
Recovery Planning
Improvements
Communications

L’ITU : L’International Telecommunication Union

ITU (Union internationale des télécommunications - Secteur de la normalisation des télécommunications) :

L'ITU élabore des normes dans le domaine des télécommunications, y compris les normes relatives aux réseaux de communication et à l'interopérabilité.

L’ANSSI : Agence Nationale de Sécurité des Systèmes d’Information

L'ANSSI (**Agence nationale de la sécurité des systèmes d'information**) est une agence gouvernementale française chargée de la sécurité informatique et de la protection des systèmes d'information sensibles en France.

Fondée en 2009, l'ANSSI opère sous l'autorité du Secrétaire général de la défense et de la sécurité nationale (SGDSN) et du Ministère des Armées.

L’ANSSI : Agence Nationale de Sécurité des Systèmes d’Information

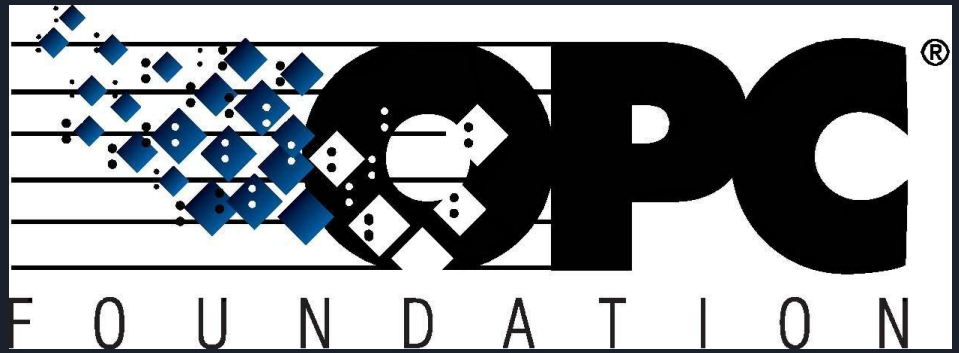
Ses principales missions comprennent la **surveillance** et la **protection des réseaux** et **systèmes d'information sensibles**, la **prévention des cyberattaques**, la **gestion des incidents de sécurité informatique**, et la promotion de **bonnes pratiques** en matière de **sécurité de l'information** au sein des administrations et des entreprises françaises.



Définitions et concepts de base

Qu'est ce qu'un standard?

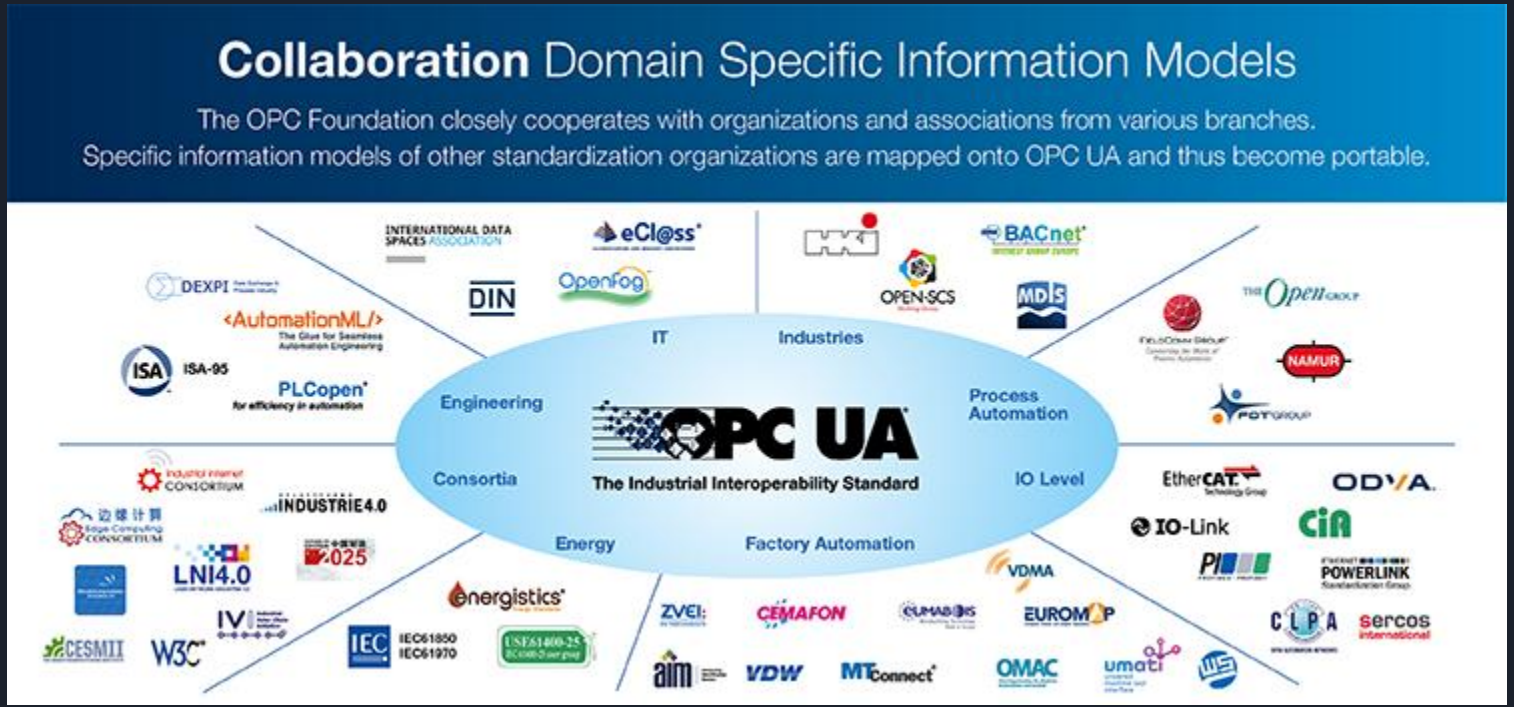
Un **standard** est un **référentiel** publié par une **entité privée** autre qu'un organisme de normalisation national ou international ou non approuvé par un de ces organismes pour un usage national ou international. On ne parle de standard qu'à partir du moment où le référentiel a une diffusion large, on parle alors de **standard de facto (standard de fait).**



L'OPC Foundation - USA

Définitions et concepts de base

Qu'est ce qu'un standard?



Etude de cas

Fonctionnement d'un organisme de normalisation

Par groupes, vous allez sélectionner un organisme et produire un document explicatif de leur fonctionnement et donner votre ressenti quant au fonctionnement de ce dernier.

La longueur du document est libre.













Cours 2 : Normes et Standards Informatiques

Les normes de Sécurité de l’Information

La sécurité de l'information est une préoccupation majeure en informatique. Les normes de sécurité définissent les bonnes pratiques pour protéger les données sensibles et les systèmes contre les menaces. Cette section se penche sur quelques-unes des normes les plus importantes.

La norme ISO 27001:2022 (date la plus récente)

L'ISO 27001 est une norme internationale pour la gestion de la sécurité de l'information. Elle établit un cadre pour l'identification des risques, la mise en place de contrôles de sécurité et la gestion continue de la sécurité.



https://www.iso.org/fr/standard/27001

Triade CID (CIA en anglais)

Confidentialité ***C**onfidentiality*	**I**ntégrité de l'Information ***I**ntegrity*	**D**isponibilité des données ***A**vailability*

Confidentialité : Seules les bonnes personnes ont accès aux informations détenues par l'organisation.

Intégrité de l'Information : Les données utilisées par l'organisation dans le cadre de ses activités ou celles dont elle assure la sécurité pour d'autres sont stockées de manière fiable et ne sont ni effacées, ni endommagées.

Disponibilité des données : L'organisation et ses client ont accès aux informations à tout moment afin de répondre aux objectifs opérationnels et aux attentes des clients.

La norme ITIL
(Information Technology Infrastructure Library)

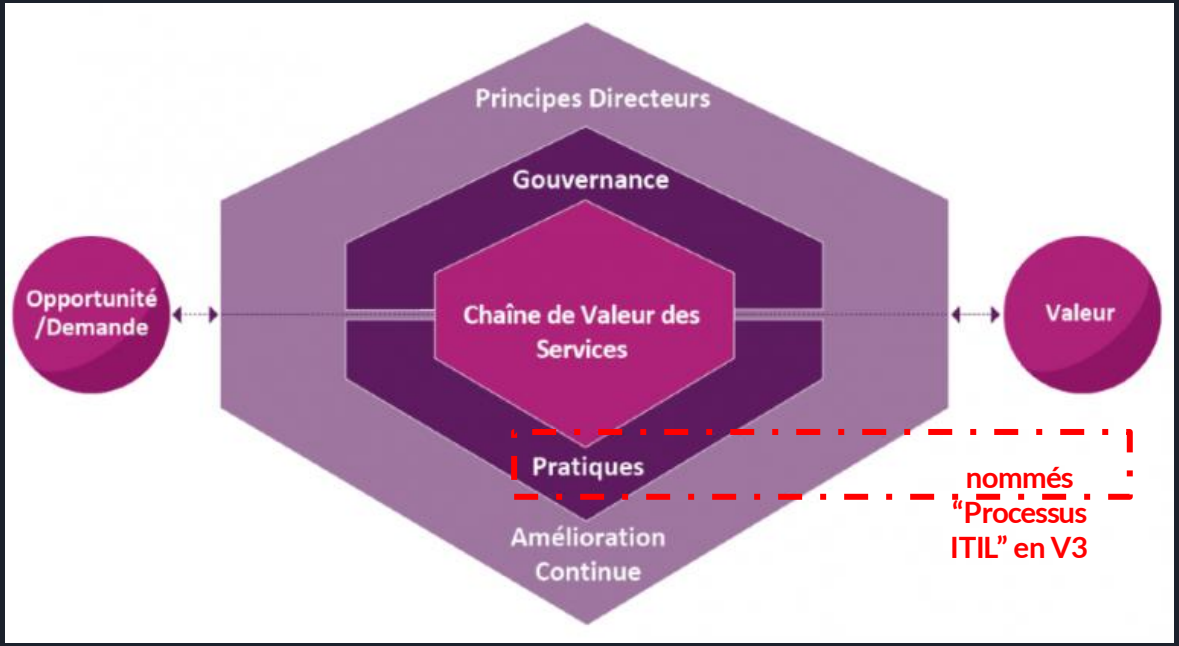
ITIL est un ensemble de bonnes pratiques pour la gestion des services informatiques. Il propose un cadre pour la planification, la mise en œuvre et la gestion des services informatiques afin d'optimiser la valeur pour l'entreprise.



Release de l'ITIL V4 (28 février 2019)

ITIL SVS *(Système de Valeur de Services)*

L'ITIL SVS montre comment différents composants d'une entreprise peuvent créer de la valeur à travers leurs services informatiques.



La norme ISO 9001

L'ISO 9001 est une norme de gestion de la qualité qui peut s'appliquer aux services informatiques. Elle met l'accent sur la satisfaction du client, l'amélioration continue et la gestion efficace des processus.



La norme PCI DSS
(Payment Card Industry Data Security Standard)

La norme de sécurité des données de l'industrie des cartes de paiement (PCI DSS) définit les exigences de sécurité pour les organisations qui traitent des paiements par carte. Elle vise à protéger les données des titulaires de cartes de crédit.



La norme ISO 22301 (PRA)

L’ISO 22301 définit les exigences pour mettre en place, maintenir et améliorer un **système de management de la continuité d’activité**. Elle vise à assurer qu’une organisation puisse continuer à fonctionner — ou redémarrer rapidement — en cas d’incident majeur (panne, cyberattaque, catastrophe, etc.).

Etude de cas
Présentation

Mise en conformité ISO 27001 pour une entreprise de Services Financiers.

Une entreprise de services financiers opère dans un environnement hautement réglementé et gère des informations sensibles telles que les données personnelles des clients et les informations financières. Cette dernière souhaite renforcer sa sécurité de l'information et garantir la conformité avec la norme ISO 27001.

La suite dans Github !

https://github.com/Le-Minh-Phuc/Gouvernances-Normes-Standards

Cours 3 : La Gouvernance Informatique

Importance de la Gouvernance en Informatique

La gouvernance informatique joue un rôle crucial dans la gestion des systèmes d'information au sein des organisations. Elle permet de s'assurer que les ressources informatiques sont utilisées de manière stratégique et responsable.

La Gouvernance IT

La Gouvernance des données

La Gouvernance IT

La gouvernance informatique fournit un cadre pour la prise de décisions basées sur des données et des analyses objectives.

Cela permet de maximiser les avantages des investissements informatiques tout en minimisant les risques.



La Gouvernance IT dans la conformité

La conformité aux normes et aux réglementations est essentielle pour éviter les sanctions légales, les violations de la sécurité et les pertes financières. La gouvernance informatique assure que les pratiques sont alignées sur les exigences légales et sectorielles.



La Gouvernance des Données

La gouvernance des données est un ensemble de **processus**, de **politiques**, de **normes** et de **pratiques** qui régissent la **gestion**, la **qualité**, **l'intégrité**, la **sécurité**, la **confidentialité** et l'**utilisation des données** au sein d'une organisation.

L'objectif principal de la gouvernance des données est de garantir que les données de l'organisation sont gérées de manière efficace, cohérente et conforme aux exigences légales et réglementaires.


GOUVERNANCE DES DONNÉES
Architecture de données
Modélisation et design de données
Stockage des données
Sécurité des données
Intégration des données et interopérabilité
Documents et contenus
Référence et données de base
Entreposage des données et intelligence d'affaires
Meta-données
Qualité des données

Gouvernance des données
Définition des responsabilités

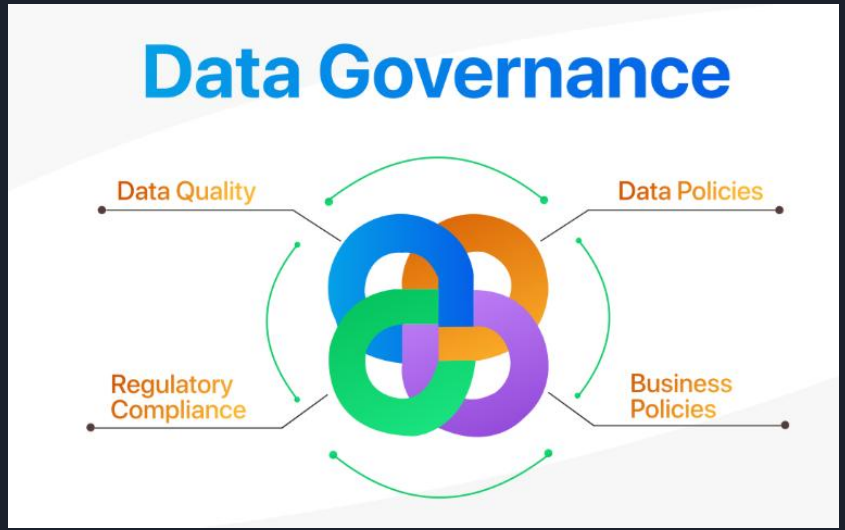
La gouvernance des données implique l'**attribution de responsabilités claires** concernant la gestion des données. Cela peut inclure la désignation de responsables de la **gestion des données**, de **responsables de la qualité des données** et d'autres **parties prenantes** chargées de veiller à ce que les données soient gérées de manière appropriée.

Formaliser les responsabilités de chacun face à la donnée

Chaque personne étant en surcharge, il était difficile de définir un périmètre sur le long terme.

Gouvernance des données : Politiques et normes

La mise en place de politiques et de **normes spécifiques** pour la **collecte**, le **stockage**, la **classification**, la **diffusion**, la **rétention** et la **destruction des données**. Ces politiques visent à garantir que les données sont utilisées de manière appropriée et sécurisée.



Gouvernance des données : Qualité des données

La gouvernance des données s'attache à maintenir la qualité des données en mettant en place des processus de **contrôle de la qualité**, des **normes de saisie de données**, des **mécanismes de nettoyage des données** et des **procédures de correction des erreurs**.

Instaurer des processus de contrôle et de blindage

La conduite du changement

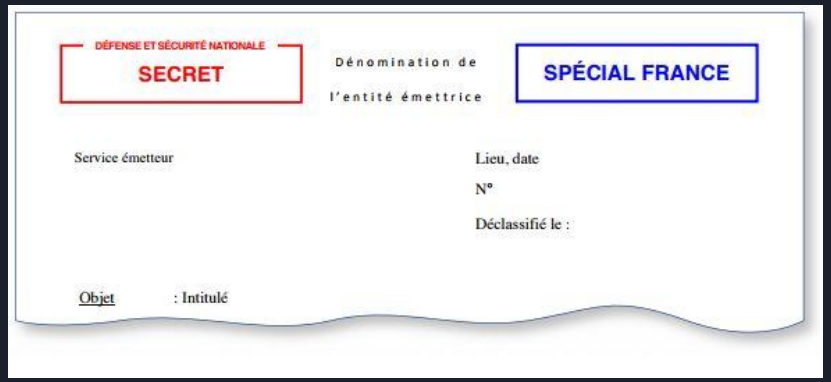
Sécurité des données

La protection des données sensibles et confidentielles est essentielle. Cela comprend la mise en place de mécanismes de sécurité informatique, de chiffrage des données, de gestion des accès et d'audit pour garantir la confidentialité et l'intégrité des données.



Conformité légale et réglementaire

La gouvernance des données s'assure que l'organisation se conforme aux l**ois et réglementations** en matière de gestion des données, notamment en ce qui concerne la **protection des données personnelles**, la **confidentialité** et d'autres exigences sectorielles.





Gestion du cycle de vie des données

Cela englobe la **gestion de la création**, de **l'utilisation**, de la **modification**, de la **conservation** et de la **suppression des données** tout au long de leur cycle de vie. Il s'agit de s'assurer que les données sont utilisées de manière appropriée et qu'elles sont éliminées de manière sécurisée lorsque cela est nécessaire.



https://www.youtube.com/watch?v=vt8PyQ2PGxI

“J’ai fouillé des disques durs sur leboncoin” Micode

La norme COBIT

La norme COBIT (Control Objectives for Information and Related Technologies) est un cadre de gouvernance et de gestion des technologies de l'information (TI) qui fournit des directives et des meilleures pratiques pour aider les organisations à atteindre leurs objectifs stratégiques en utilisant efficacement et en toute sécurité les systèmes informatiques.



La norme COBIT

COBIT a été développé par l'ISACA (Information Systems Audit and Control Association) et est largement utilisé dans le monde entier.

Ses principaux éléments comprennent un modèle de processus, des objectifs de contrôle, des principes fondamentaux et un ensemble de bonnes pratiques pour la gouvernance des TI.



COBIT®

PRINCIPLES
Governance System

1. Provide Stakeholder Value
2. Holistic Approach
3. Dynamic Governance System
4. Governance Distinct From Management
5. Tailored to Enterprise Needs
6. End-to-End Governance System

PRINCIPLES
Governance Framework

1. Based on Conceptual Model
2. Open and Flexible
3. Aligned to Major Standards

Objectif de la norme COBIT

COBIT vise à améliorer la gestion des TI, à assurer la conformité aux réglementations, à gérer les risques informatiques et à mesurer la performance des processus informatiques, le tout dans le but d'aligner les TI sur les objectifs métier de l'organisation.

Fondamentaux de COBIT 4.1 et COBIT 5

Les lois et réglementations en UE et en France

Les lois et réglementations en France et dans l’UE

Connaissez vous des lois ou réglementations qui régissent notre système aujourd’hui ?

Le Data Governance Act

Le **Data Governance Act** et le **Data Act** s'inscrivent dans le cadre de la **stratégie européenne pour les données**, présentée par la Commission européenne en février 2020. Cette stratégie vise à développer un marché unique de la donnée en soutenant **l'accès**, le **partage** et la **réutilisation** responsables, dans le respect des valeurs de l'Union européenne et notamment la **protection des données personnelles**.

Elle s'inscrit dans le contexte plus large du plan d'action de la Commission européenne visant à assurer la **souveraineté numérique** de l'Europe à l'horizon **2030**, et est complémentaire de la stratégie européenne en matière d'intelligence artificielle.

Le Data Governance Act

Première brique de la série de mesures annoncées dans le cadre de la stratégie européenne des données, le Data Governance Act a été adopté en **mai 2022**, et sera applicable en **septembre 2023**. Il vise à favoriser le partage des données personnelles et non personnelles en mettant en place des structures d'intermédiation. Ce règlement comporte 4 grandes mesures.

Le Data Governance Act

Un encadrement ainsi qu'une assistance technique et juridique facilitant la **réutilisation** de certaines catégories de données protégées du secteur public (informations commerciales confidentielles, propriété intellectuelle, données personnelles)

Une certification **obligatoire** pour les fournisseurs de services d'intermédiation de données.

Une certification **facultative** pour les organismes pratiquant l'altruisme en matière de données.

La création du "**Conseil Européen de l'innovation en matière de données**"

Le Data Act

La proposition législative de la Commission européenne, présentée le **23 février 2022**, a pour objectif d'assurer une meilleure répartition de la valeur issue de l'utilisation des données personnelles et non personnelles entre les acteurs de l'économie de la donnée, notamment liées à l'utilisation des objets connectés et au développement de l'Internet des objets.

Le Data Act

Faciliter le partage entre entreprises (B2B) et avec le consommateur (B2C) des données, en fixant notamment une obligation de rendre accessibles les données générées par l'utilisation des objets connectés et services connexes, en contrepartie d'une compensation juste et équitable.

Permettre l'utilisation des données détenues par les entreprises et, sous réserve de justifier d'un besoin exceptionnel, par les organismes publics des États membres et les institutions, agences ou organes de l'Union.

Le Data Act

Faciliter le changement de fournisseur de services de traitement de données (cloud et edge computing) par l'encadrement des relations contractuelles entre les fournisseurs de services et les consommateurs, et notamment par la suppression progressive des frais liés au changement pour le consommateur.

Prévoir l'élaboration de normes d'interopérabilité pour les données et leurs réutilisations entre les secteurs.

Mettre en place des garanties contre les accès illicites de gouvernements de pays tiers aux données non-personnelles contenues dans le cloud.

La loi informatique et libertés

La France a mis en place sa propre législation nationale sur la protection des données bien avant l'adoption du RGPD. La Loi Informatique et Libertés définit les règles applicables au traitement des données personnelles en France.



https://www.cnil.fr/fr/la-loi-informatique-et-libertes

La réglementation DORA (Digital Operational Resilience Act)

Adopté en 2022, entre en vigueur en 2025

Harmoniser les exigences de résilience opérationnelle numérique au niveau de l'Union européenne.

Renforcer la capacité des institutions financières à résister, répondre et se rétablir face à des perturbations opérationnelles graves liées aux TIC.

Améliorer la prévention et la gestion des incidents TIC et des cybermenaces.

Établir un mécanisme de surveillance direct des prestataires de services TIC critiques au niveau de l'UE.

DORA - Règlement Européen pour la finance

Règlement européen qui vise à garantir que tous les acteurs du secteur financier restent opérationnels même en cas de cyberattaque

Qui est concerné ?

- Banques, assurances
- Gestionnaires d'actifs / fonds
- Fintechs
- Plateformes crypto
- Prestataires IT critiques : cloud, data centers, services de paiement

Ce que DORA impose

- Gestion des risques numériques
- Capables de continuer à fonctionner
- Mettre en place des protections
- Identification des risques cyber
- Tests obligatoires de résilience
- Tests réguliers des plans de sécurité
- Simulations d'attaque (tests de pénétration avancés pour les grandes entités)
- Obligation de notifier les incidents graves
- Alerte en 24h → rapport complet en 72h
- Gouvernance renforcée
- dirigeants responsables de la cybersécurité
- Supervision des prestataires IT
- Presta critiques (cloud, SaaS) surveillés
- Contrôle des fournisseurs par banques et fintechs
- UE peut imposer des correctifs aux prestas

Pourquoi c'est important ?

Pour les citoyens

- Réduire le risque de coupure de service bancaire
- Mieux protéger les données financières
- Augmentation de la stabilité et de la transparence

Pour les entreprises

- Culture de la résilience obligatoire
- Réduction des risques systémiques
- Harmonisation européenne
  Mêmes règles dans tous les états

NIS2 - Directive européenne (2024 - 2025)

Objectif

Renforcer la cybersécurité et la résilience des secteurs essentiels en Europe

Qui est concerné ?

- Santé, énergie, transport, eau
- Banques, assurances
- Administrations publiques
- Fournisseurs numériques *(cloud, DNS, datacenters)*
- Entreprises critiques même de taille moyenne

Ce que NIS2 impose

Mesures de cybersécurité obligatoires

- Contrôle des accès
- MFA
- Gestion des risques
- Sauvegardes
- Mises à jour

Plans de gestion de crise

- PRA
- PCA

Obligation de notifier les incidents graves

- Alerte en 24h → rapport complet en 72h

Gouvernance renforcée

- Les dirigeants sont responsables de la cybersécurité

Pourquoi c'est important ?

- Meilleure protection des services essentiels du quotidien
- Moins d'interruptions (santé, électricité, transport)
- Plus de transparence et de réactivité face aux cyberattaques

Rôles et responsabilités des parties prenantes dans la gouvernance IT

Dans le cadre de la gouvernance des technologies de l'information (IT), diverses parties prenantes interviennent, chacune ayant des rôles et des responsabilités spécifiques pour assurer que les systèmes informatiques sont gérés de manière efficace, sécurisée et conforme aux objectifs de l'organisation.

Etude de cas 3 : Mise en oeuvre de la gouvernance informatique

Etude de cas dans Github !

https://github.com/Le-Minh-Phuc/Gouvernances-Normes-Standards/blob/main/%C3%89tude%20de%20Cas%203%20_%20Mise%20en%20%C5%92uvre%20de%20la%20Gouvernance%20Informatique.pdf

Cours 4 : Normes pour la Confidentialité et la Sécurité

Normes pour la Confidentialité et la Sécurité

Les normes européennes et françaises en matière de gestion de données

Que connaissez vous comme normes existantes aujourd’hui ?

Les normes européennes : Le RGPD

Règlement général sur la protection des données (RGPD) : Le RGPD est le principal texte de référence en matière de protection des données personnelles en Europe. Il a été adopté en **2018** et s'applique à toutes les entreprises qui traitent des **données personnelles de résidents européens.** Il définit les principes fondamentaux de **protection des données**, les **droits des individus** et les **obligations des responsables du traitement des données.**

https://www.cnil.fr/fr/reglement-europeen-protection-donnees

Les directives NIS

Directive NIS : La directive sur la sécurité des réseaux et des systèmes d'information (NIS) vise à renforcer la cybersécurité au sein de l'Union européenne en imposant des obligations de sécurité aux opérateurs de services essentiels et aux fournisseurs de services numériques.

PRÉSENTATION DE LA DIRECTIVE

Structurée autour de quatre axes, la directive prévoit

- le renforcement des capacités nationales de cybersécurité. Les Etat membres devront notamment se doter d'autorités nationales compétentes en matière de cybersécurité, d'équipes nationales de réponse aux incidents informatiques (CSIRT) et de stratégies nationales de cybersécurité. Respectivement en France, l'ANSSI, le CERT-FR↗ et la stratégie nationale pour la sécurité du numérique ;
- l'établissement d'un cadre de coopération volontaire entre Etats membres de l'UE via la création de
  - un « groupe de coopération » des Etats membres sur les aspects politiques de la cybersécurité ;
  - un « réseau européen des CSIRT » des Etats membres. Ce dernier visera notamment à faciliter le partage d'informations techniques sur les risques, vulnérabilités ;
- le renforcement par chaque Etat de la cybersécurité d'« opérateurs de services essentiels » au fonctionnement de l'économie et de la société via
  - la définition au niveau national de règles de cybersécurité auxquels ces derniers devront se conformer ;
  - l'obligation pour les opérateurs de notifier les incidents ayant un impact sur la continuité de leurs services essentiels.
- l'instauration de règles européennes communes en matière de cybersécurité des prestataires de services numériques dans les domaines de l'informatique en nuage, des moteurs de recherche et places de marché en ligne.

NIS2 - Directive européenne (2024 - 2025)

Objectif

Renforcer la cybersécurité et la résilience des secteurs essentiels en Europe

Qui est concerné ?

- Santé, énergie, transport, eau
- Banques, assurances
- Administrations publiques
- Fournisseurs numériques *(cloud, DNS, datacenters)*
- Entreprises critiques même de taille moyenne

Ce que NIS2 impose

Mesures de cybersécurité obligatoires

- Contrôle des accès
- MFA
- Gestion des risques
- Sauvegardes
- Mises à jour

Plans de gestion de crise

- PRA
- PCA

Obligation de notifier les incidents graves

- Alerte en 24h → rapport complet en 72h

Gouvernance renforcée

- Les dirigeants sont responsables de la cybersécurité

Pourquoi c'est important ?

- Meilleure protection des services essentiels du quotidien
- Moins d'interruptions (santé, électricité, transport)
- Plus de transparence et de réactivité face aux cyberattaques

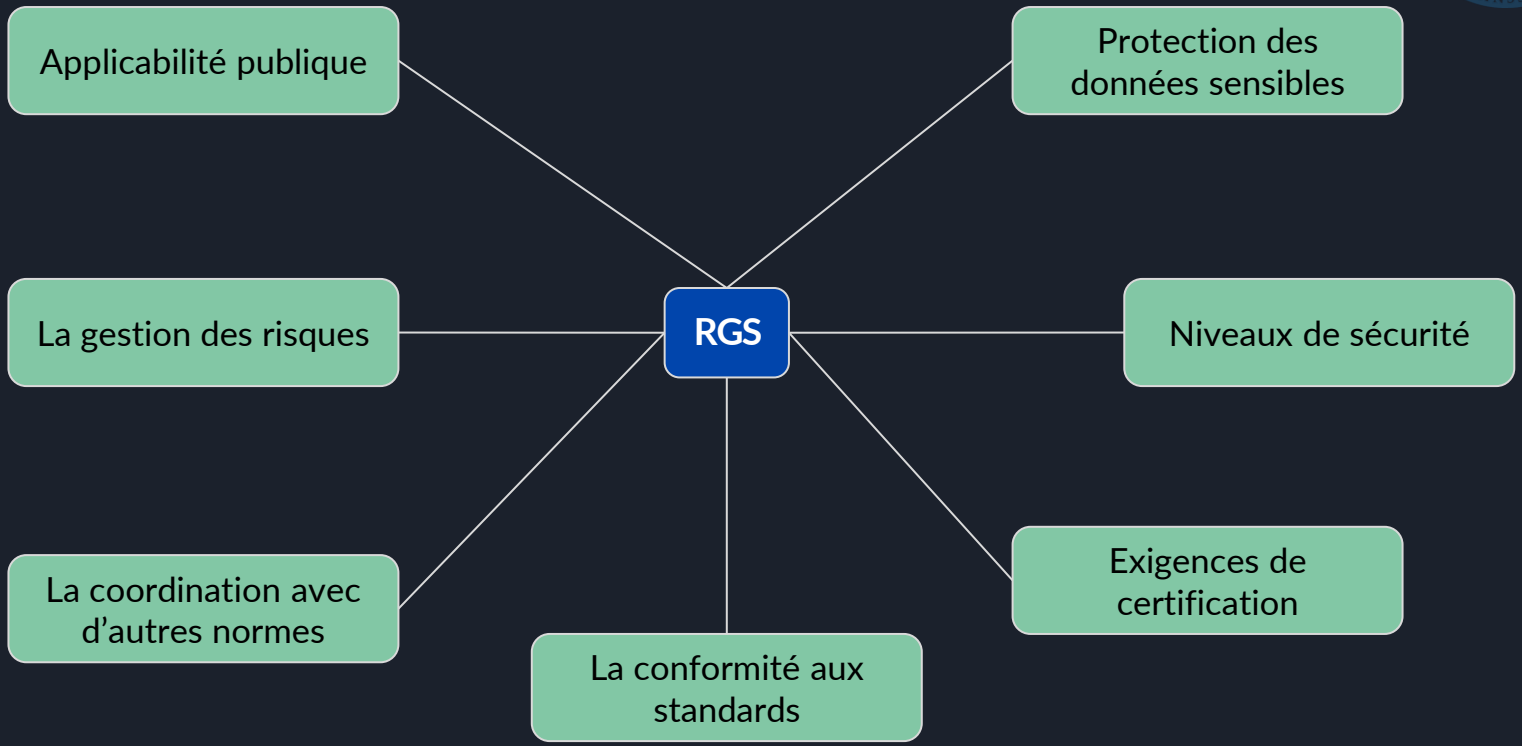
Le Référentiel Général de Sécurité (RGS)

Le Référentiel Général de Sécurité, souvent abrégé en RGS, est un cadre de référence et de normes de sécurité informatique spécifiquement conçu pour les administrations et les organismes publics en France. Le RGS a pour principal objectif de garantir la sécurité des systèmes d'information et la protection des données sensibles au sein de ces entités gouvernementales.

https://www.ssi.gouv.fr/entreprise/reglementation/confiance-numerique/le-referentiel-general-de-securite-rgs/

https://www.ssi.gouv.fr/administration/reglementation/confiance-numerique/le-referentiel-general-de-securite-rgs/liste-des-documents-constitutifs-du-rgs-v-2-0/

Le Référentiel Général de Sécurité (RGS)



L’applicabilité publique du RGS

Le RGS s'applique principalement aux administrations et aux organismes publics en France. Il vise à établir des normes de sécurité pour protéger les informations sensibles et les services publics.

Administration nationale

Administration locale

Social, santé

Enseignement, recherche

Travail, emploi, formation

Environnement, logement, transports

Economie, finances, consommation

Sécurité, défense

Associations, culture, jeunesse

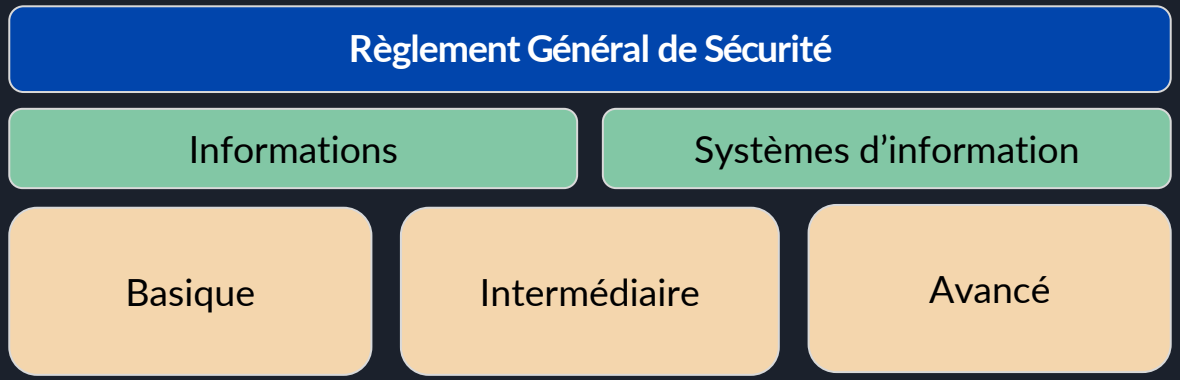
Droit, justice

La Protection des données sensibles

Le RGS définit des exigences de sécurité pour assurer la confidentialité, l'intégrité et la disponibilité des données sensibles, notamment les données personnelles des citoyens.

Les niveaux de sécurité du RGS

Le RGS catégorise les informations et les systèmes en trois niveaux de sécurité (de base, intermédiaire, et avancé) en fonction de leur sensibilité. Chaque niveau de sécurité définit des mesures de sécurité spécifiques.



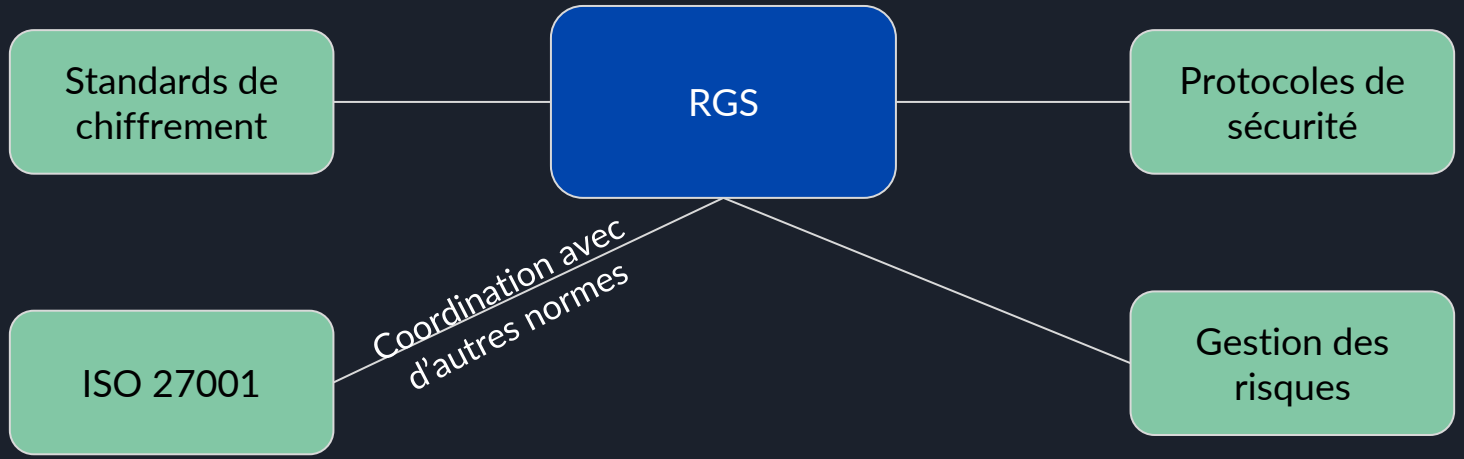
Les exigences de certification du RGS

Certains systèmes et services utilisés par les administrations publiques doivent être certifiés conformes au RGS pour garantir qu'ils respectent les normes de sécurité requises.



La conformité aux Standards

Le RGS s'appuie sur des normes de sécurité reconnues, telles que les standards de chiffrement, les protocoles de sécurité, et d'autres références en matière de sécurité informatique.



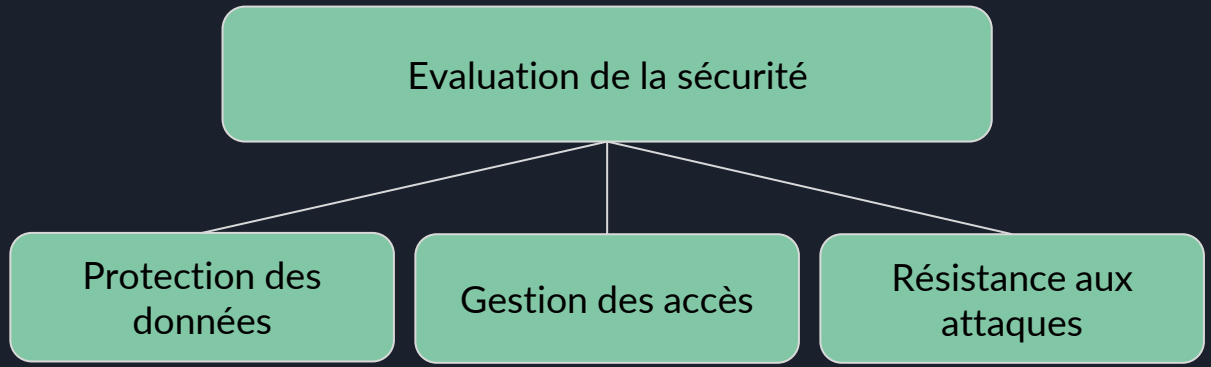
La certification de Sécurité de Premier Niveau (CSPN)

La **Certification de Sécurité de Premier Niveau** (CSPN) est un processus de certification de sécurité informatique en France qui évalue et atteste que des produits informatiques, principalement utilisés par les administrations publiques, respectent des exigences minimales de sécurité établies par l'ANSSI. Elle vise à renforcer la sécurité des systèmes informatiques gouvernementaux et à assurer la conformité aux normes de sécurité.



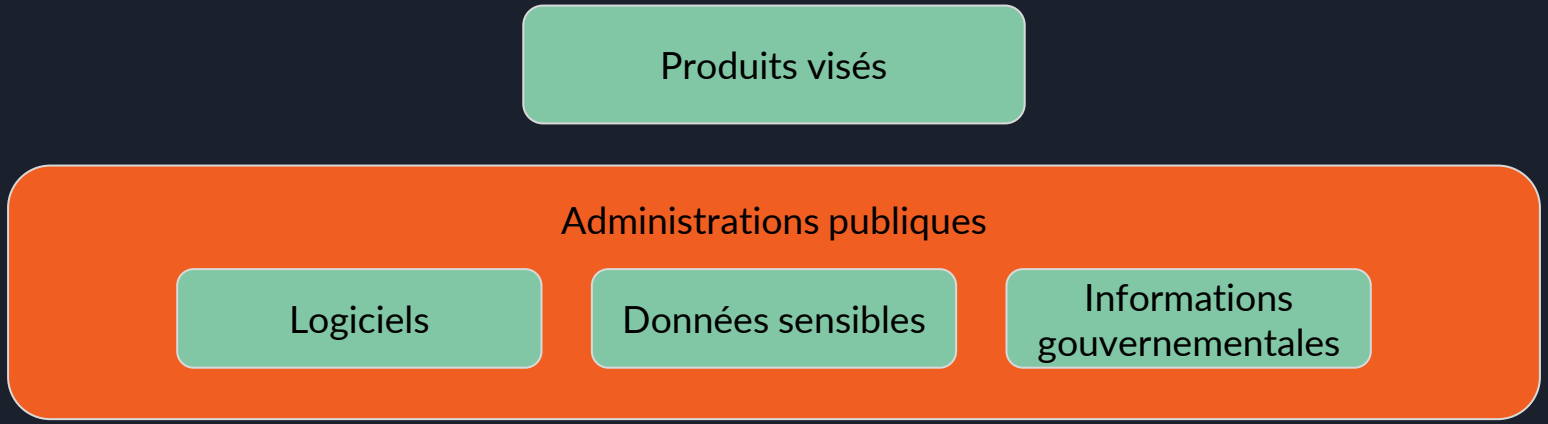
La certification de Sécurité de Premier Niveau (CSPN)

La CSPN vise à évaluer la sécurité d'un produit informatique en vérifiant s'il respecte un ensemble de critères et de mesures de sécurité définis par l'Agence nationale de la sécurité des systèmes d'information (ANSSI) en France.



La certification de Sécurité de Premier Niveau (CSPN)

La CSPN s'applique principalement aux logiciels et aux systèmes utilisés par les administrations publiques, y compris les solutions informatiques qui traitent des données sensibles ou des informations gouvernementales.



La certification de Sécurité de Premier Niveau (CSPN)

Les produits certifiés CSPN doivent satisfaire aux exigences minimales de sécurité énoncées par l'ANSSI.

- Protection des données
- Gestion des accès
- Cryptographie
- Chiffrement

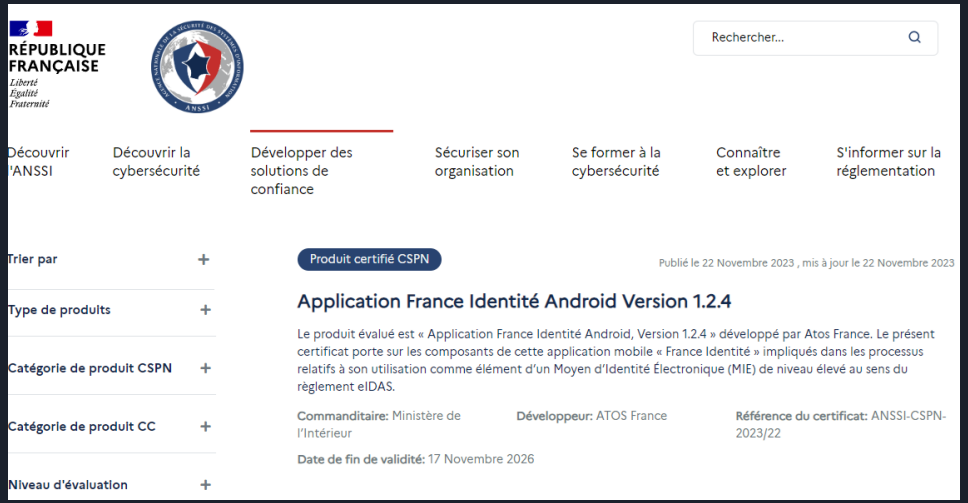
La certification de Sécurité de Premier Niveau (CSPN)

La certification CSPN implique une évaluation approfondie du produit par des experts en sécurité informatique.

- Tests de vulnérabilité
- Audits de code source
- Analyse de logs
- Analyses de sécurité

La certification de Sécurité de Premier Niveau (CSPN)

Si le produit réussit l'évaluation et répond aux exigences de sécurité, il reçoit le label CSPN délivré par l'ANSSI. Ce label atteste que le produit a été évalué et jugé conforme aux normes de sécurité minimales.



https://cyber.gouv.fr/produits-certifies

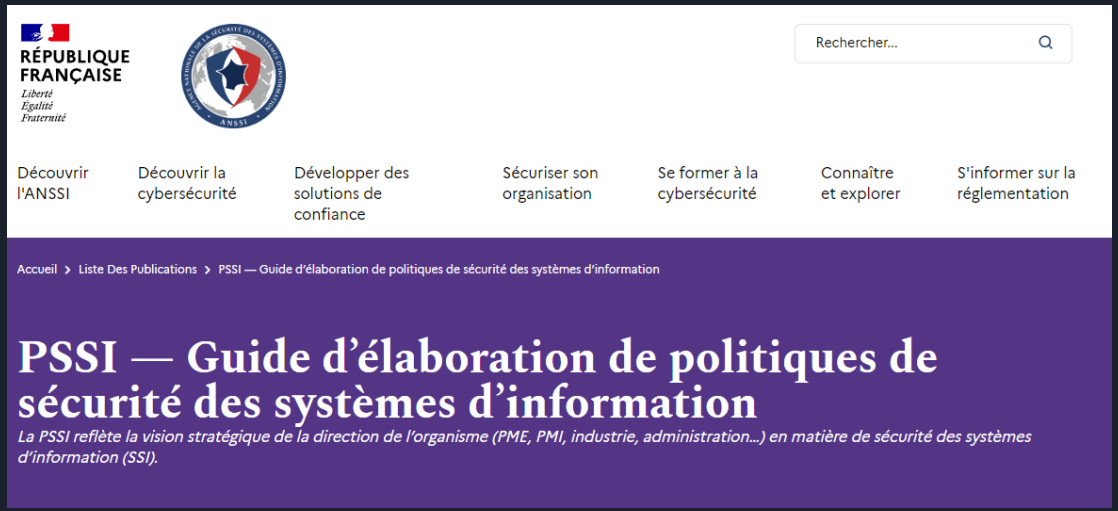
La certification de Sécurité de Premier Niveau (CSPN)

La CSPN démontre l'engagement envers la sécurité et la conformité aux normes de sécurité. Elle peut être requise pour l'utilisation de produits informatiques au sein des administrations publiques et offre une assurance de sécurité aux utilisateurs finaux.



La politique de Sécurité des Systèmes d'Information (PSSI)

La Politique de Sécurité des Systèmes d'Information (PSSI) est un document stratégique créé en qui définit les principes, les objectifs, les responsabilités et les mesures de sécurité pour protéger les systèmes d'information au sein d'une organisation.



https://cyber.gouv.fr/publications/pssi-guide-delaboration-de-politiques-de-securite-des-systemes-dinformation

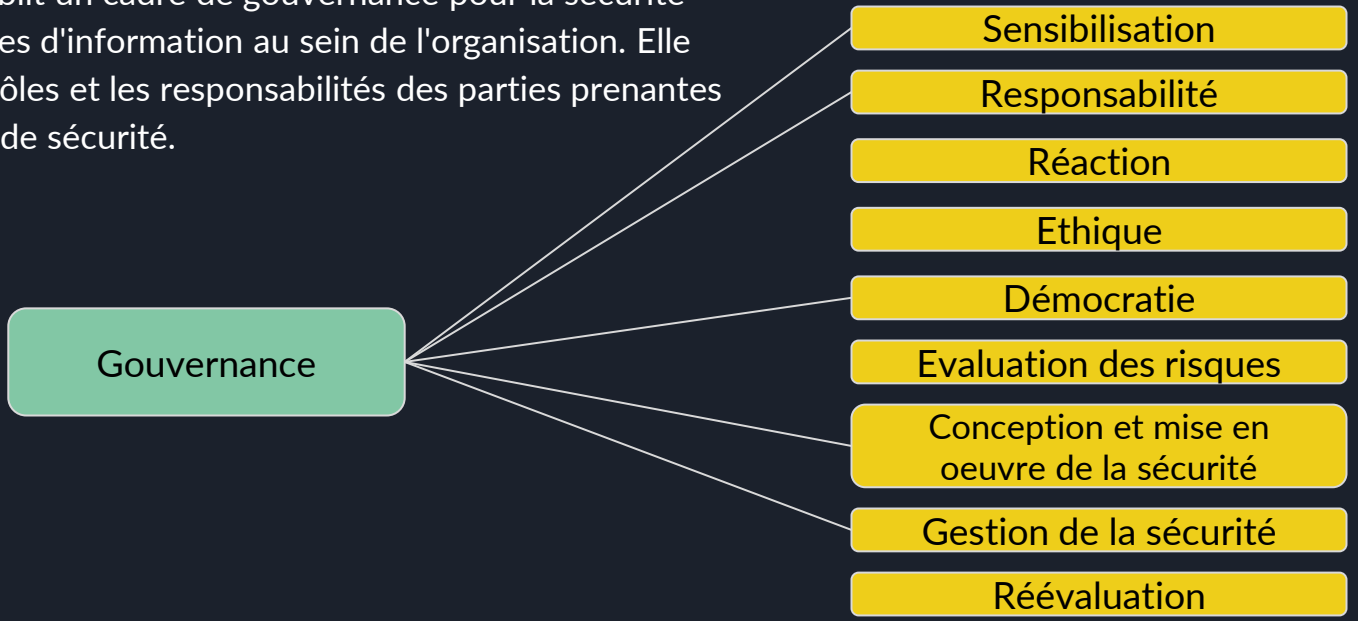
La politique de Sécurité des Systèmes d'Information (PSSI)

La PSSI regroupe 9 lignes directrices provenant de l'OCDE

- Sensibilisation
- Responsabilité
- Réaction
- Ethique
- Démocratie
- Evaluation des risques
- Conception et mise en oeuvre de la sécurité
- Gestion de la sécurité
- Réévaluation

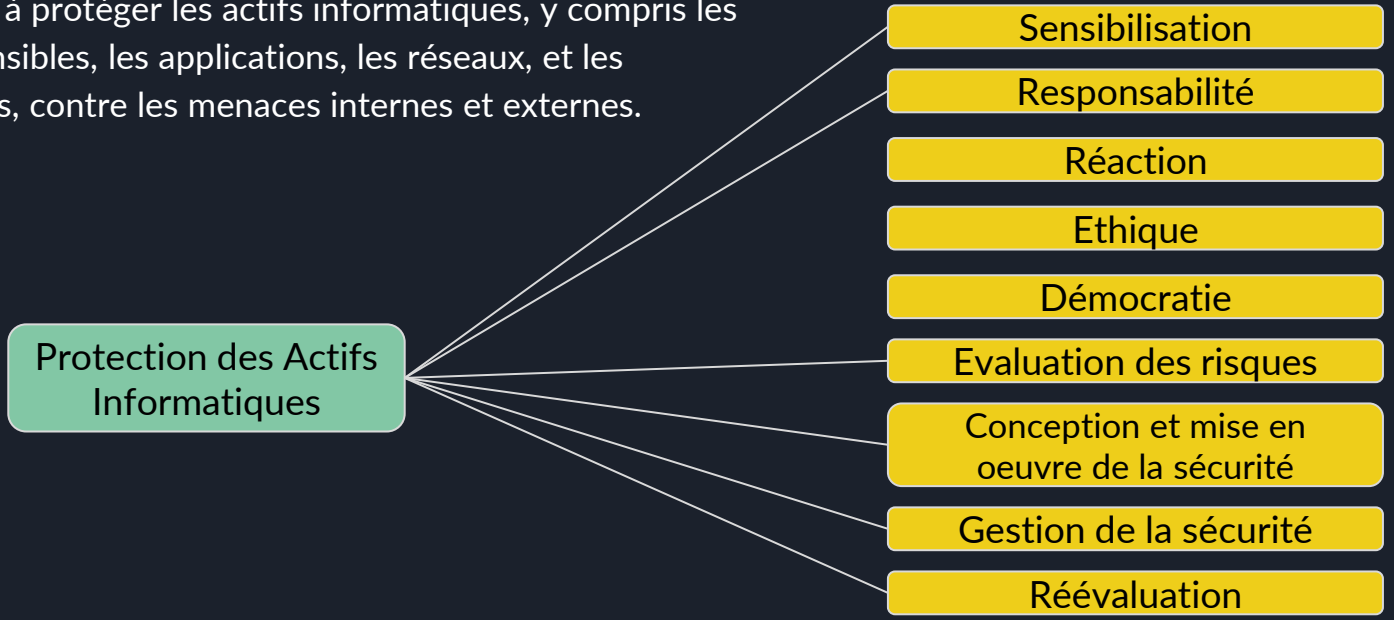
La politique de Sécurité des Systèmes d'Information (PSSI) et la gouvernance IT

La PSSI établit un cadre de gouvernance pour la sécurité des systèmes d'information au sein de l'organisation. Elle définit les rôles et les responsabilités des parties prenantes en matière de sécurité.



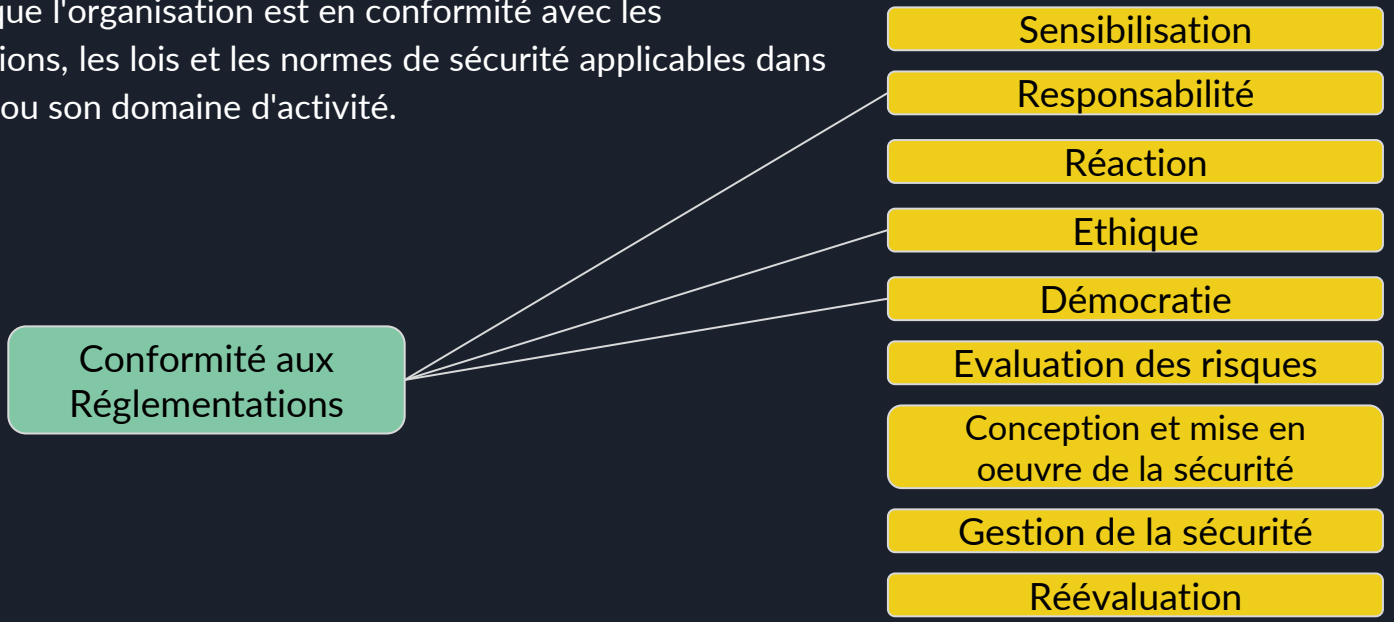
La politique de Sécurité des Systèmes d'Information (PSSI)

La PSSI vise à protéger les actifs informatiques, y compris les données sensibles, les applications, les réseaux, et les équipements, contre les menaces internes et externes.



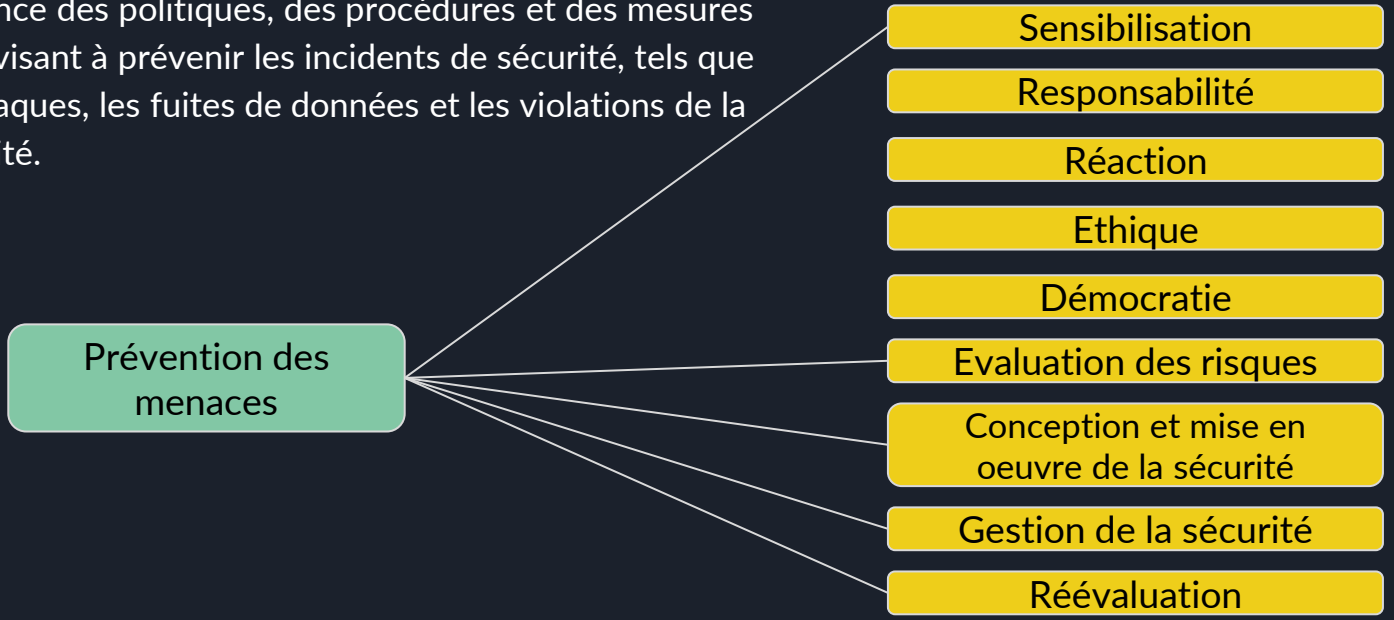
La politique de Sécurité des Systèmes d'Information (PSSI)

Elle assure que l'organisation est en conformité avec les réglementations, les lois et les normes de sécurité applicables dans son secteur ou son domaine d'activité.



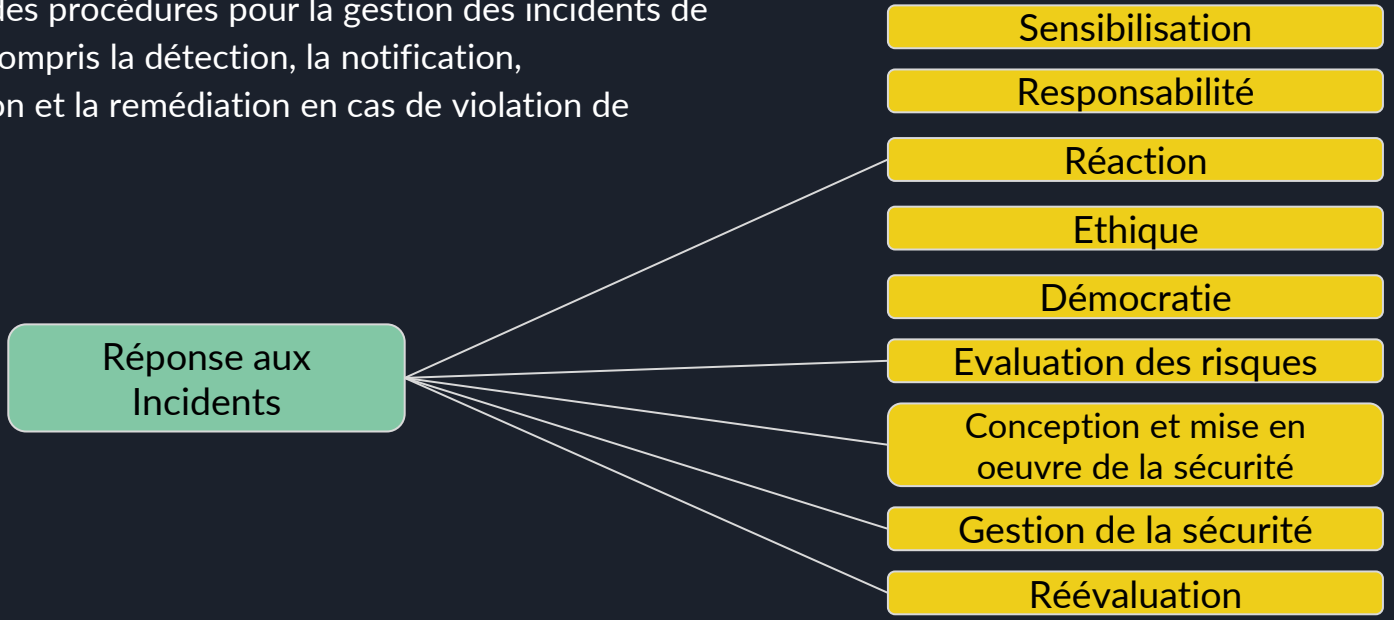
La politique de Sécurité des Systèmes d'Information (PSSI)

La PSSI énonce des politiques, des procédures et des mesures de sécurité visant à prévenir les incidents de sécurité, tels que les cyberattaques, les fuites de données et les violations de la confidentialité.



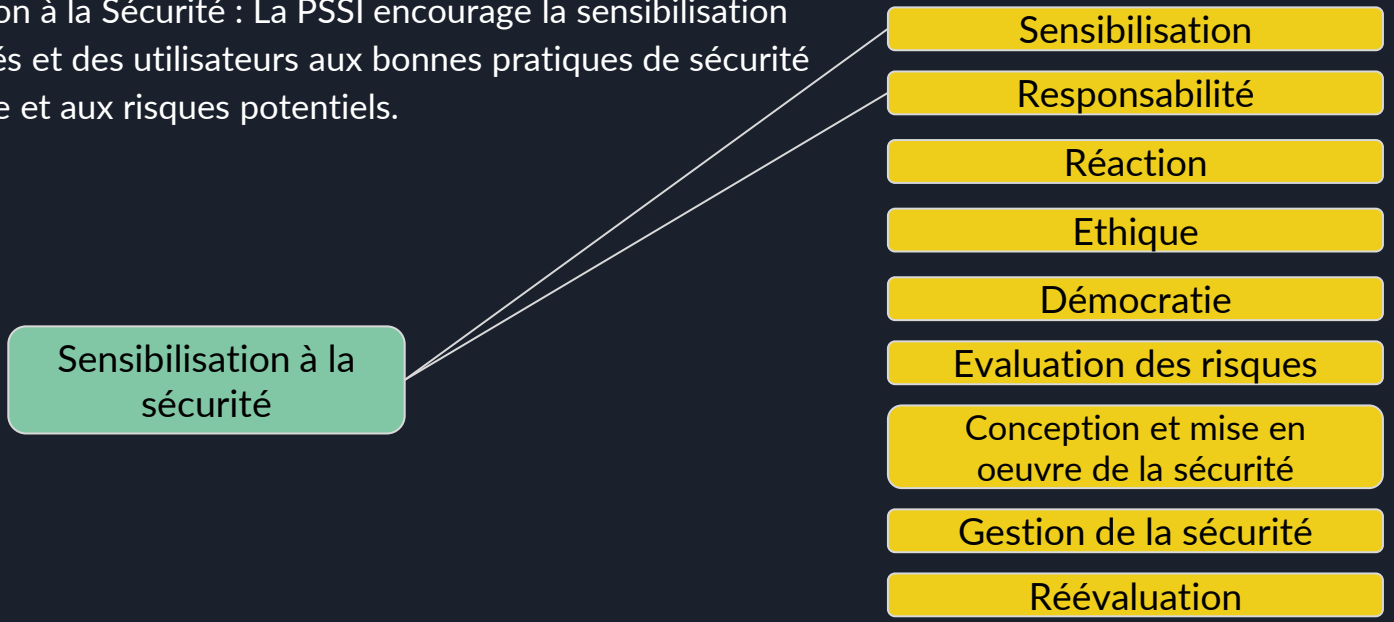
La politique de Sécurité des Systèmes d'Information (PSSI)

Elle définit des procédures pour la gestion des incidents de sécurité, y compris la détection, la notification, l'investigation et la remédiation en cas de violation de sécurité.



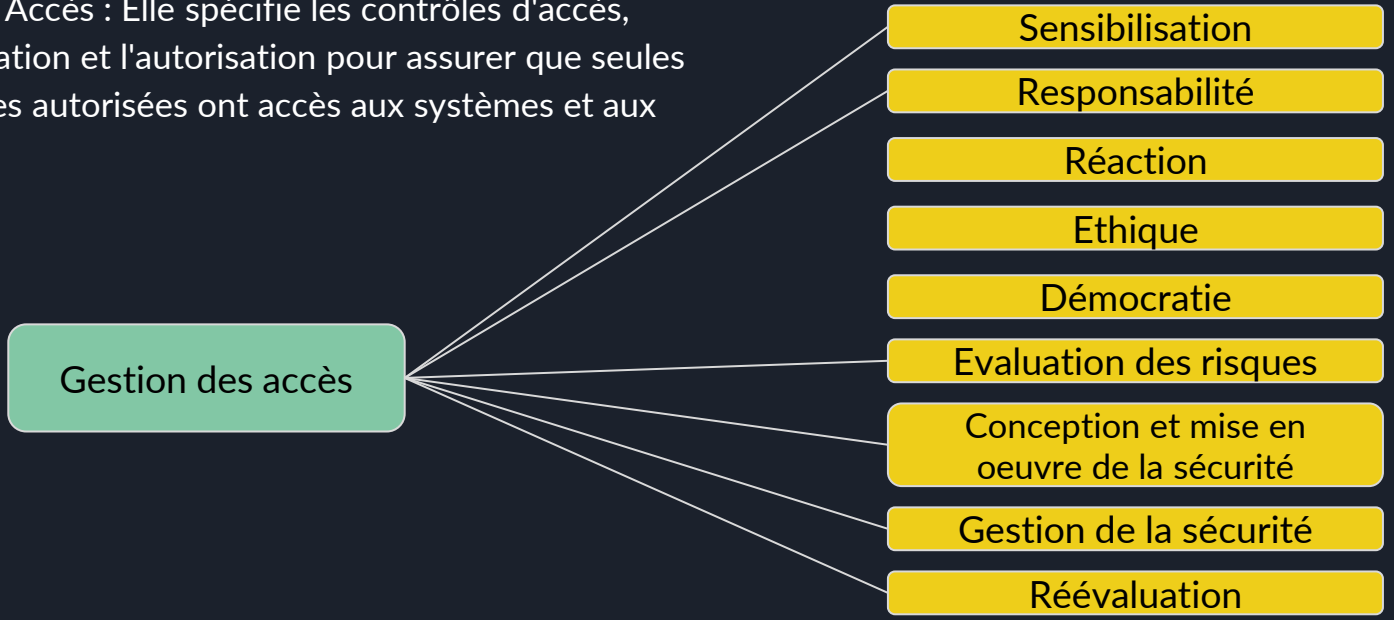
La politique de Sécurité des Systèmes d'Information (PSSI)

Sensibilisation à la Sécurité : La PSSI encourage la sensibilisation des employés et des utilisateurs aux bonnes pratiques de sécurité informatique et aux risques potentiels.



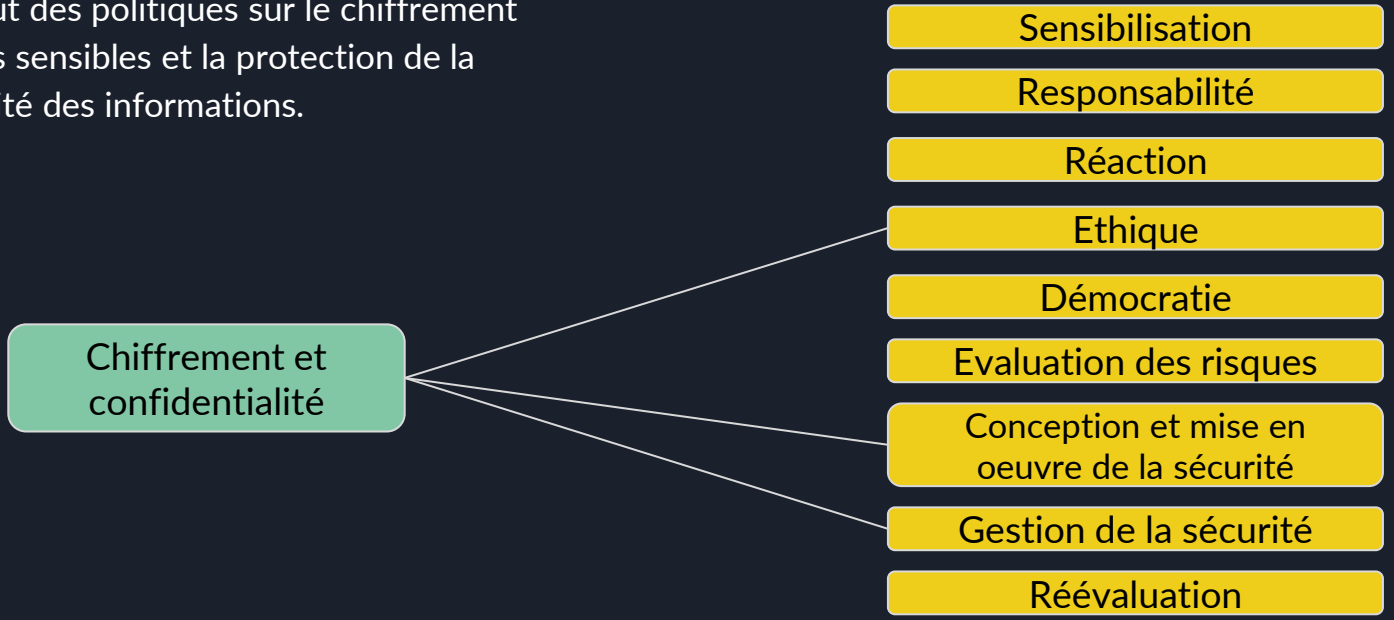
La politique de Sécurité des Systèmes d'Information (PSSI)

Gestion des Accès : Elle spécifie les contrôles d'accès, l'authentification et l'autorisation pour assurer que seules les personnes autorisées ont accès aux systèmes et aux données.



La politique de Sécurité des Systèmes d'Information (PSSI)

La PSSI inclut des politiques sur le chiffrement des données sensibles et la protection de la confidentialité des informations.



Etude de cas (1h)

Vous allez sélectionner un document parmi les 3 proposés et faire une étude sur comment ce document répond aux exigences de cybersécurité que l'on peut retrouver dans les entreprises d'aujourd'hui.

Groupe 1	Groupe 2	Groupe 3
RGS Règlement Général de Sécurité	CSPN Certification de Sécurité de Premier Niveau	PSSI Politique de Sécurité des Systèmes d'Information

Vous devrez citer vos sources ainsi que des passages des documents explicites (page et citation)

Powerpoint Exigé

Cours 5 : Normes pour la gestion des risques

Rappel : La gestion des risques

La gestion des risques est la discipline visant à identifier, évaluer et hiérarchiser les risques liés aux activités d'une organisation quelque soit leur provenance et les traiter méthodiquement afin de réduire et contrôler la probabilité des évènements redoutés et leur impact sur éventuel.



La norme ISO 31000:2018 pour la gestion des risques

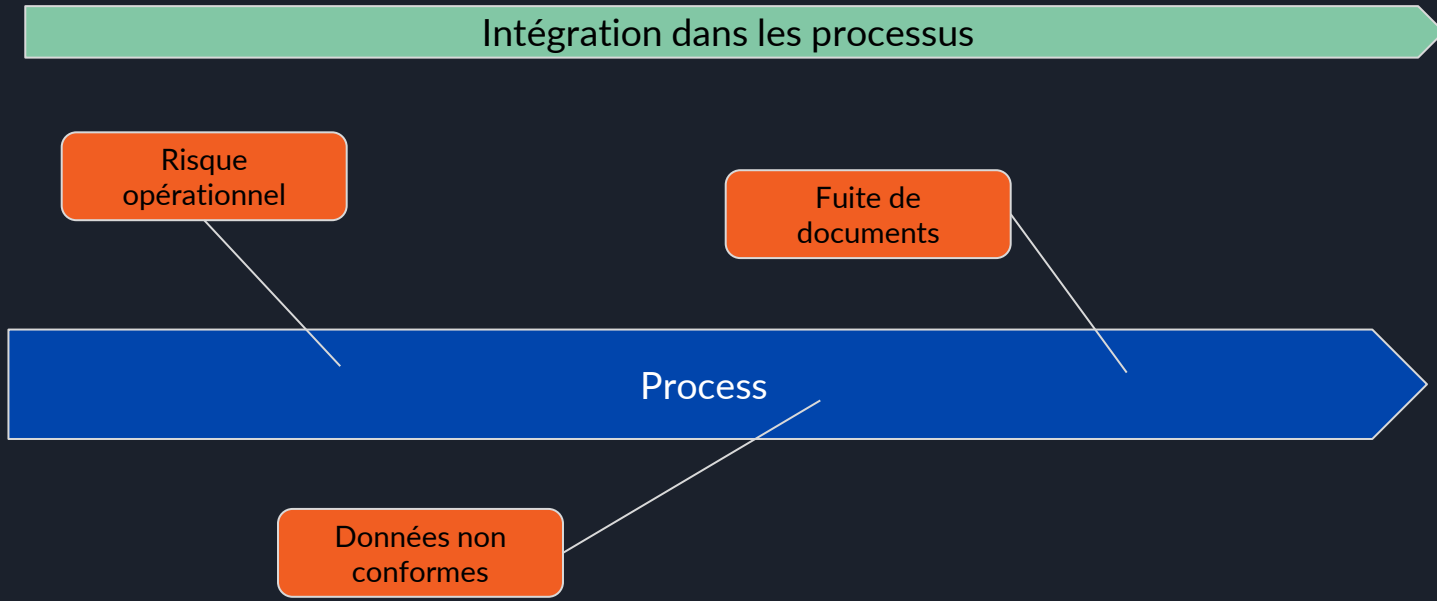
La norme ISO 31000:2018 vise à promouvoir une approche systématique et cohérente de la gestion des risques au sein des organisations, qu'elles soient publiques, privées ou à but non lucratif.

La norme ISO 31000:2018 est un cadre international de gestion des risques qui fournit des lignes directrices et des principes pour aider les organisations à identifier, évaluer, atténuer et gérer efficacement les risques.

https://www.iso.org/fr/iso-31000-risk-management.html

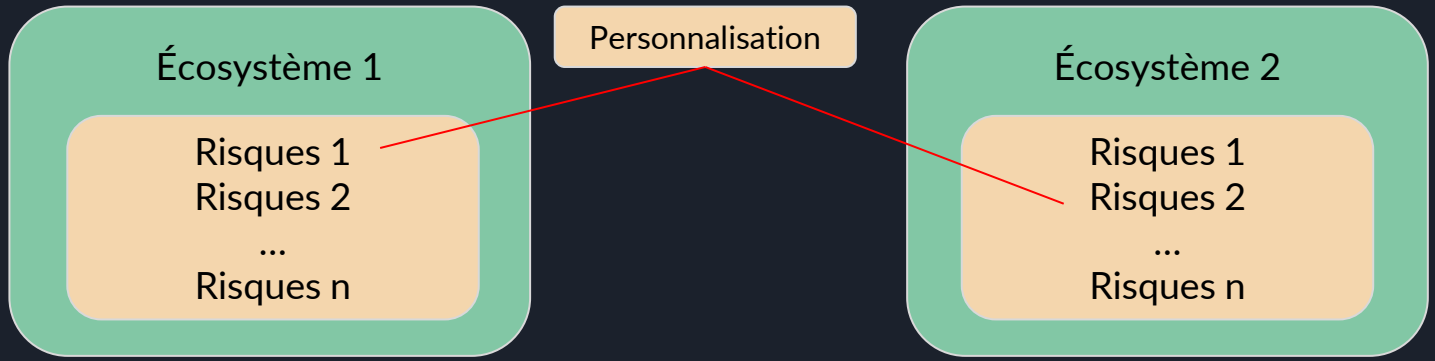
La norme ISO 31000:2018 pour la gestion des risques

La gestion des risques doit être intégrée dans tous les processus de l'organisation, de la planification stratégique à l'exécution opérationnelle.



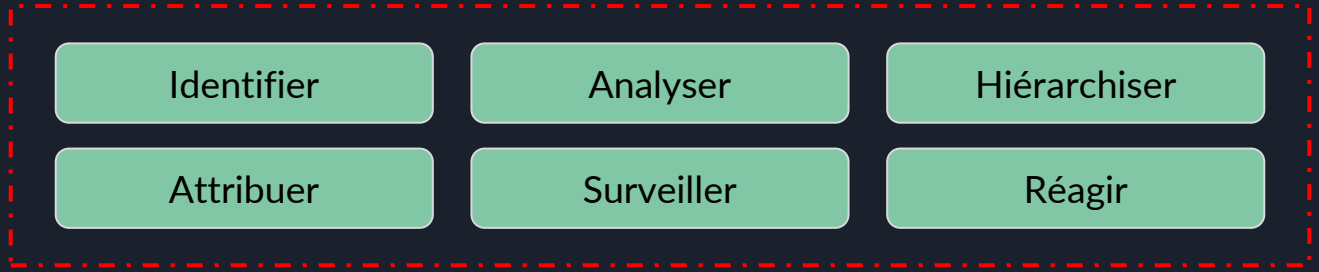
La norme ISO 31000:2018 pour la gestion des risques

La méthode de gestion des risques doit être adaptée aux besoins spécifiques de l'organisation, tenant compte de sa culture, de sa structure et de ses objectifs.



La norme ISO 31000:2018 pour la gestion des risques

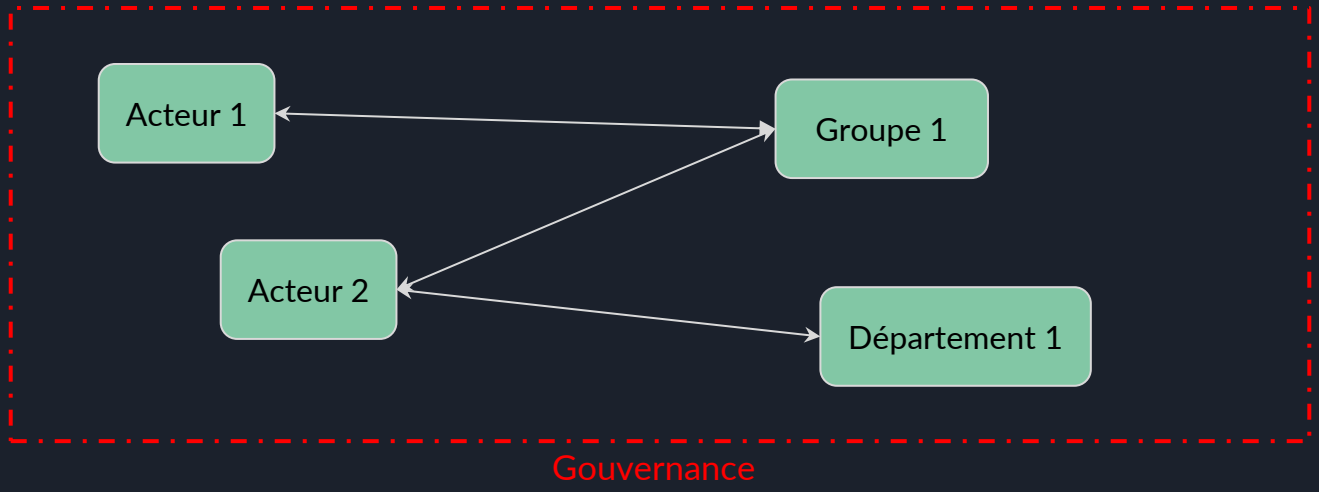
La norme encourage l'utilisation des meilleures pratiques de gestion des risques.



https://asana.com/fr/resources/project-risk-management-process

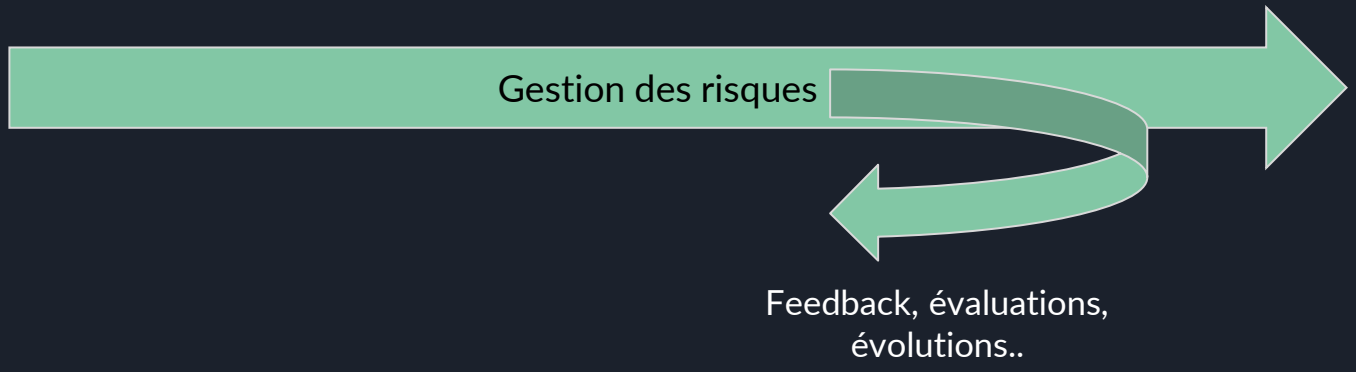
La norme ISO 31000:2018 pour la gestion des risques

La gestion des risques est une responsabilité de tous les niveaux de l'organisation, de la direction à chaque employé.

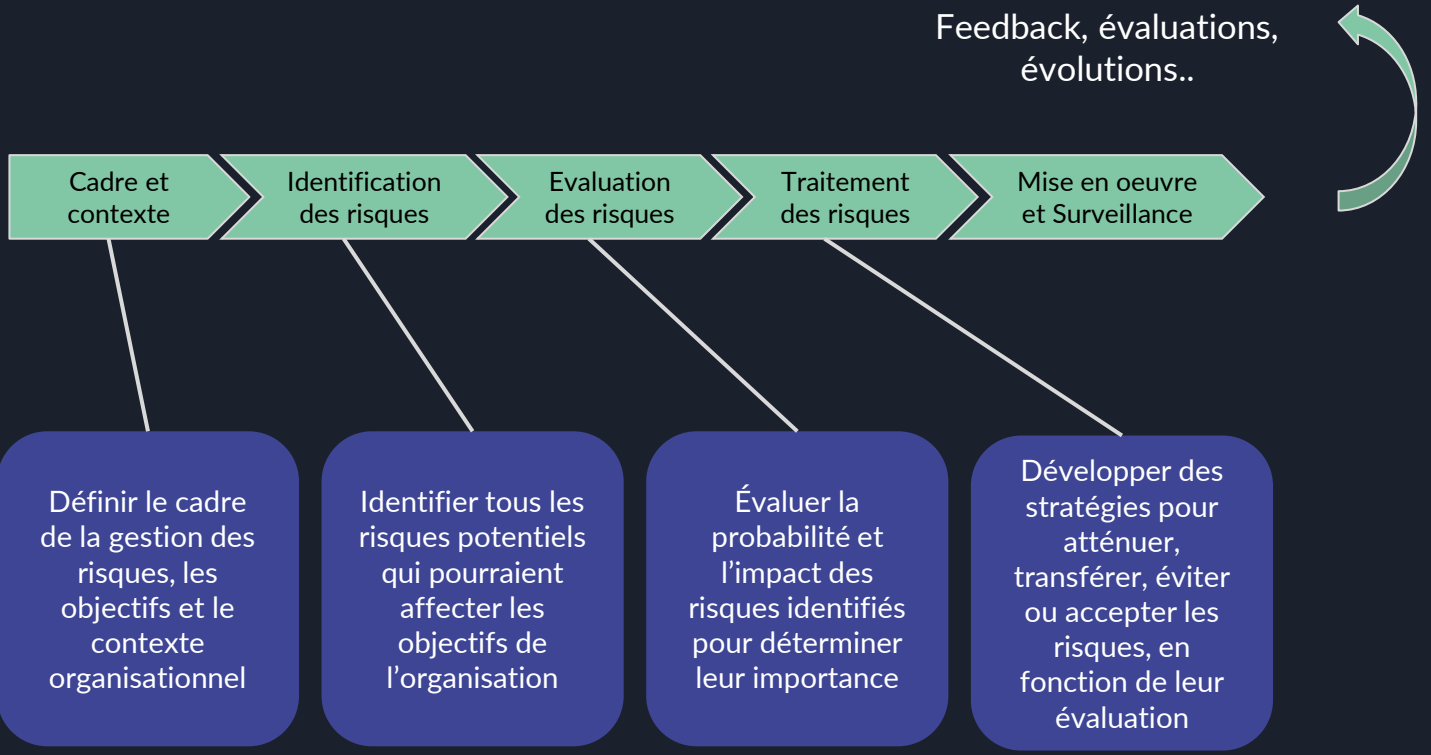


La norme ISO 31000 pour la gestion des risques

Évaluation Continue : La gestion des risques est un processus continu qui nécessite une évaluation régulière et une adaptation aux évolutions de l'environnement organisationnel.



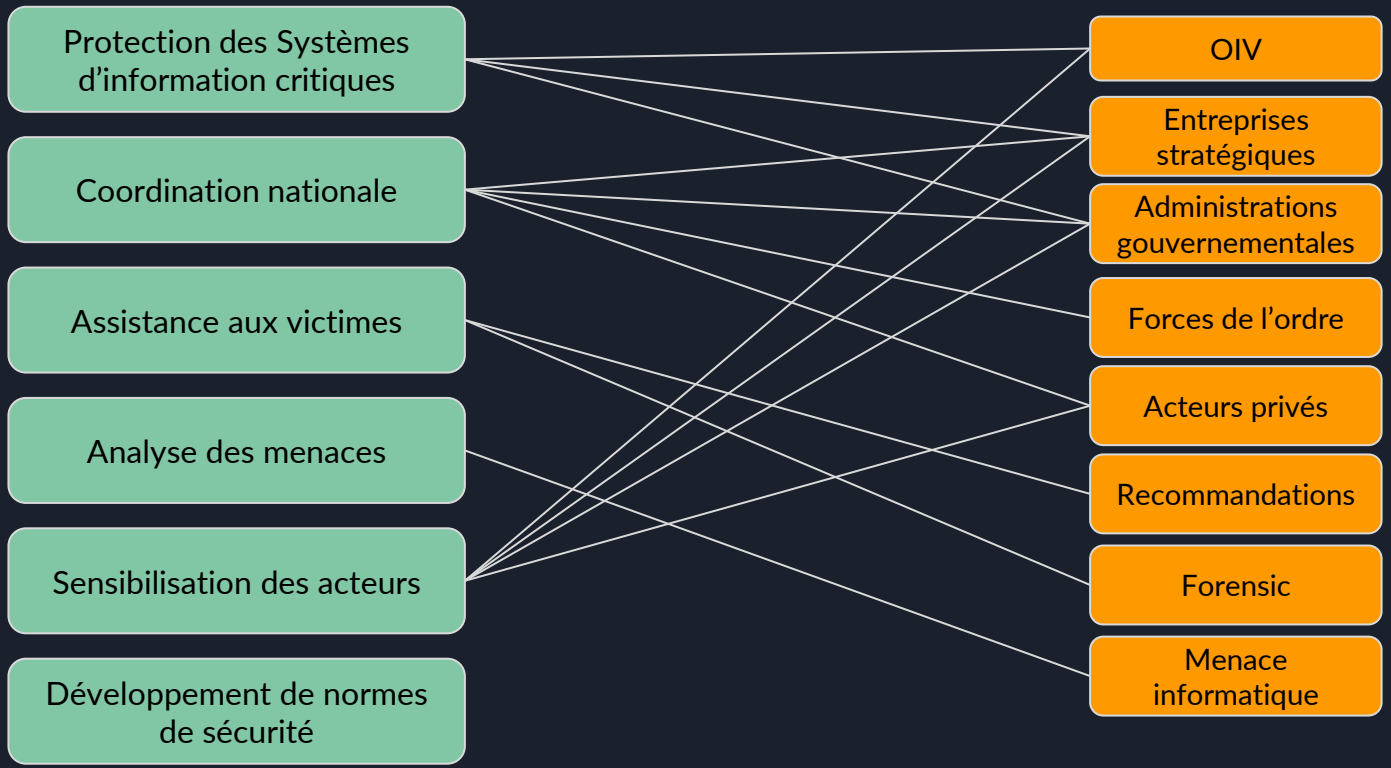
Étapes de la norme ISO 31000 pour la gestion des risques



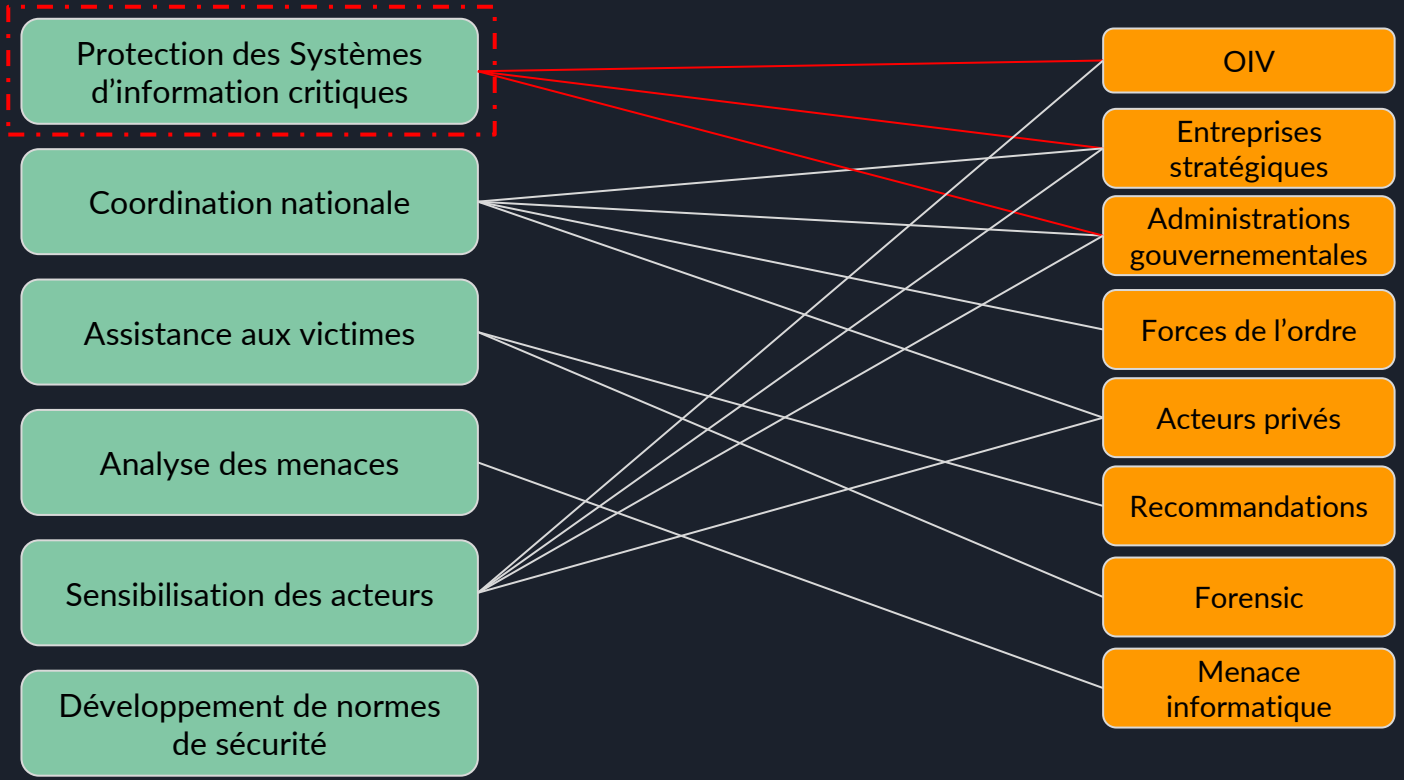
La gestion des incidents de sécurité

La gestion des incidents de sécurité est une composante essentielle de la cybersécurité, et l'ANSSI (Agence nationale de la sécurité des systèmes d'information) en France joue un rôle crucial dans ce domaine.

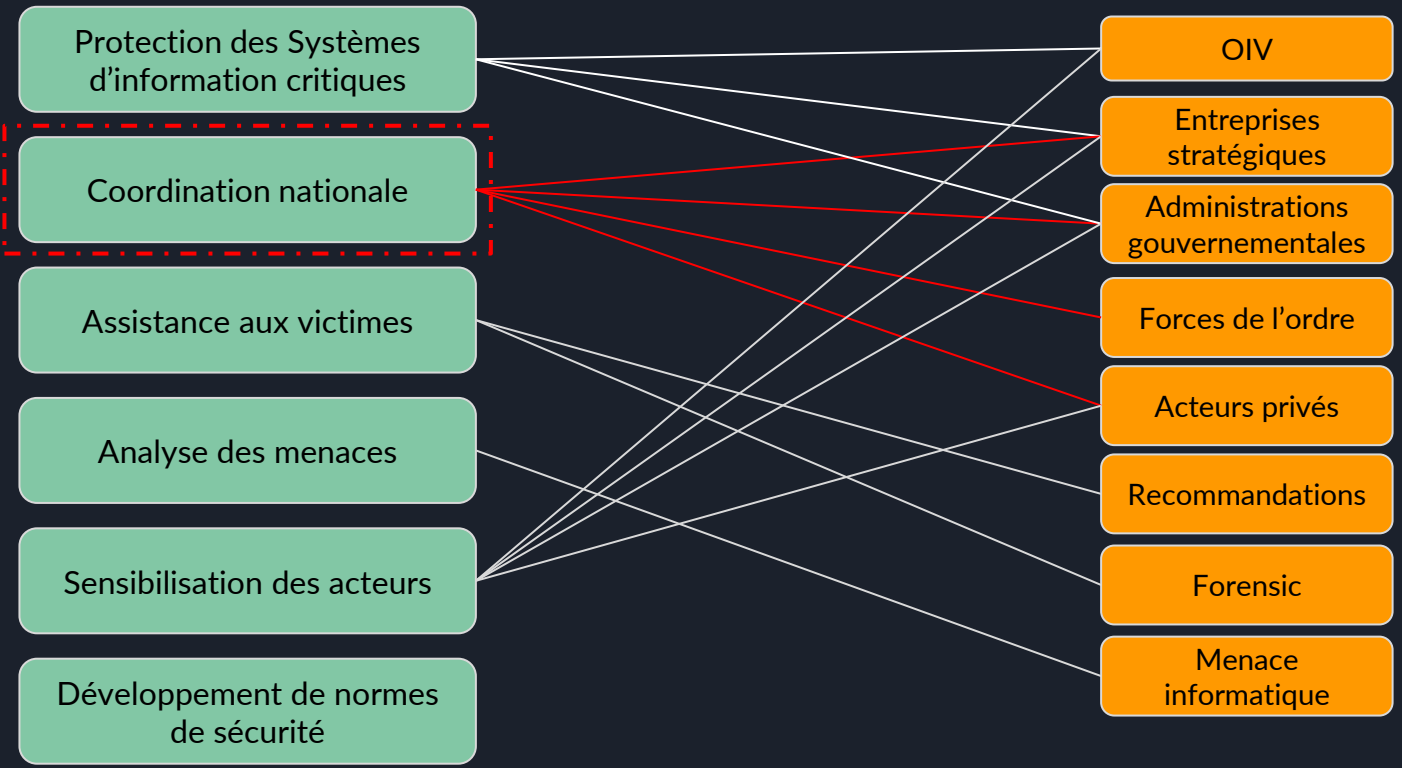
Objectifs de la gestion des incidents de sécurité par l'ANSSI



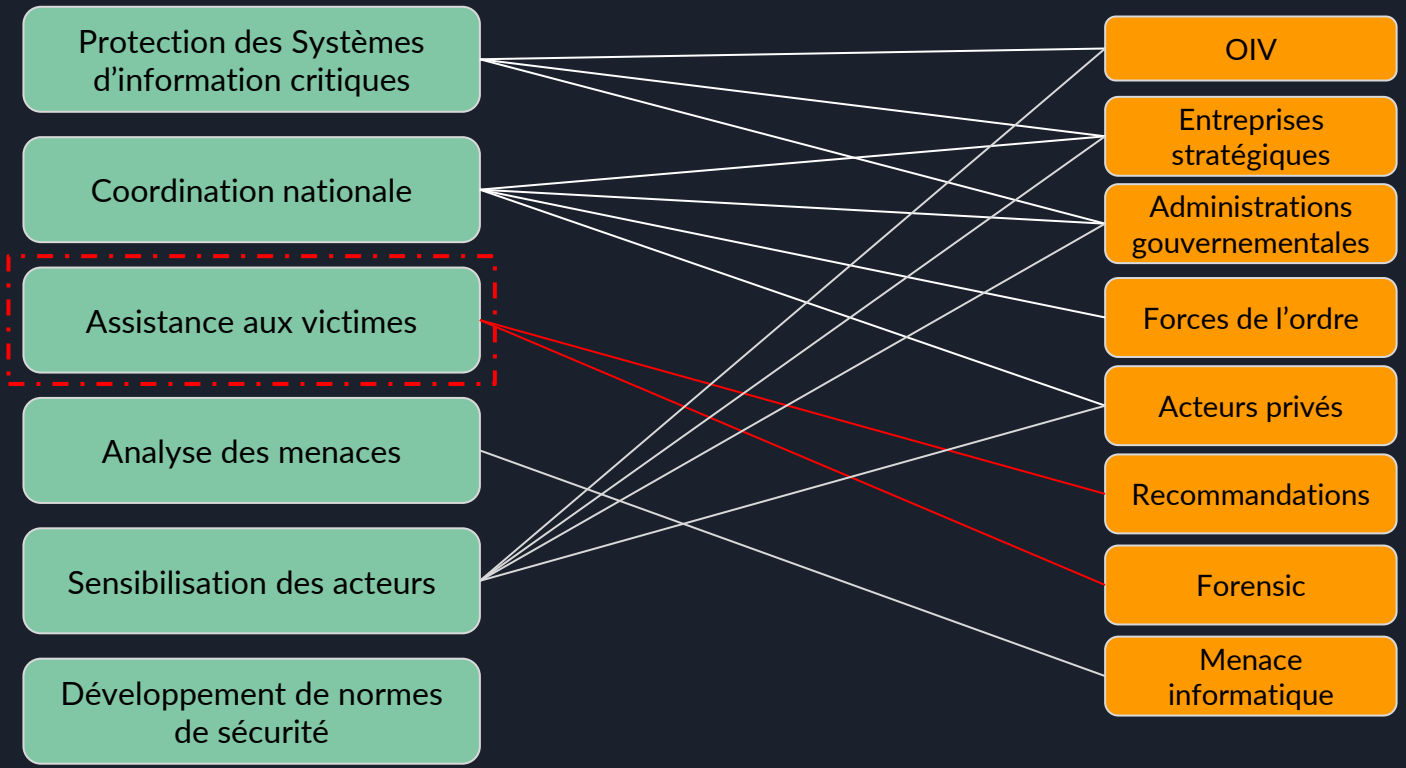
Objectifs de la gestion des incidents de sécurité par l'ANSSI



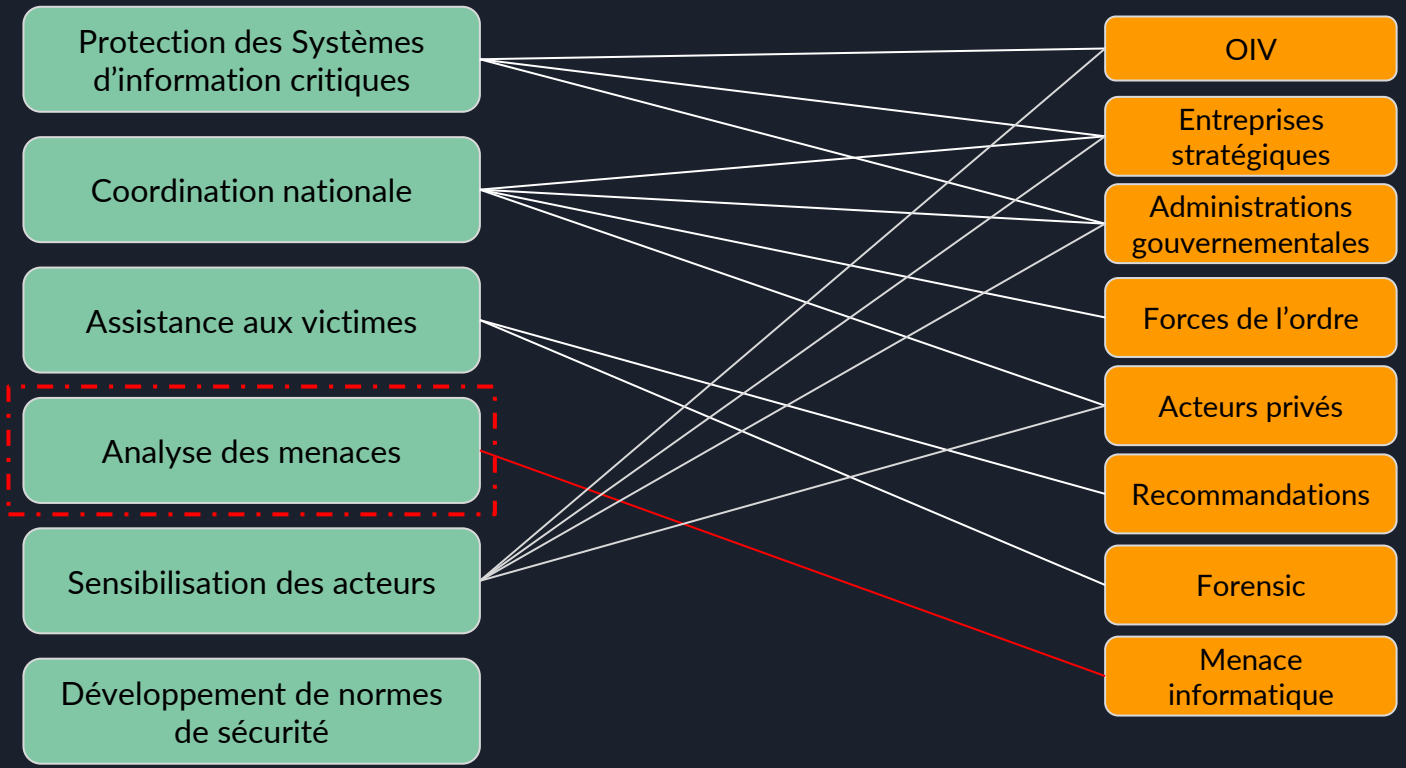
Objectifs de la gestion des incidents de sécurité par l'ANSSI



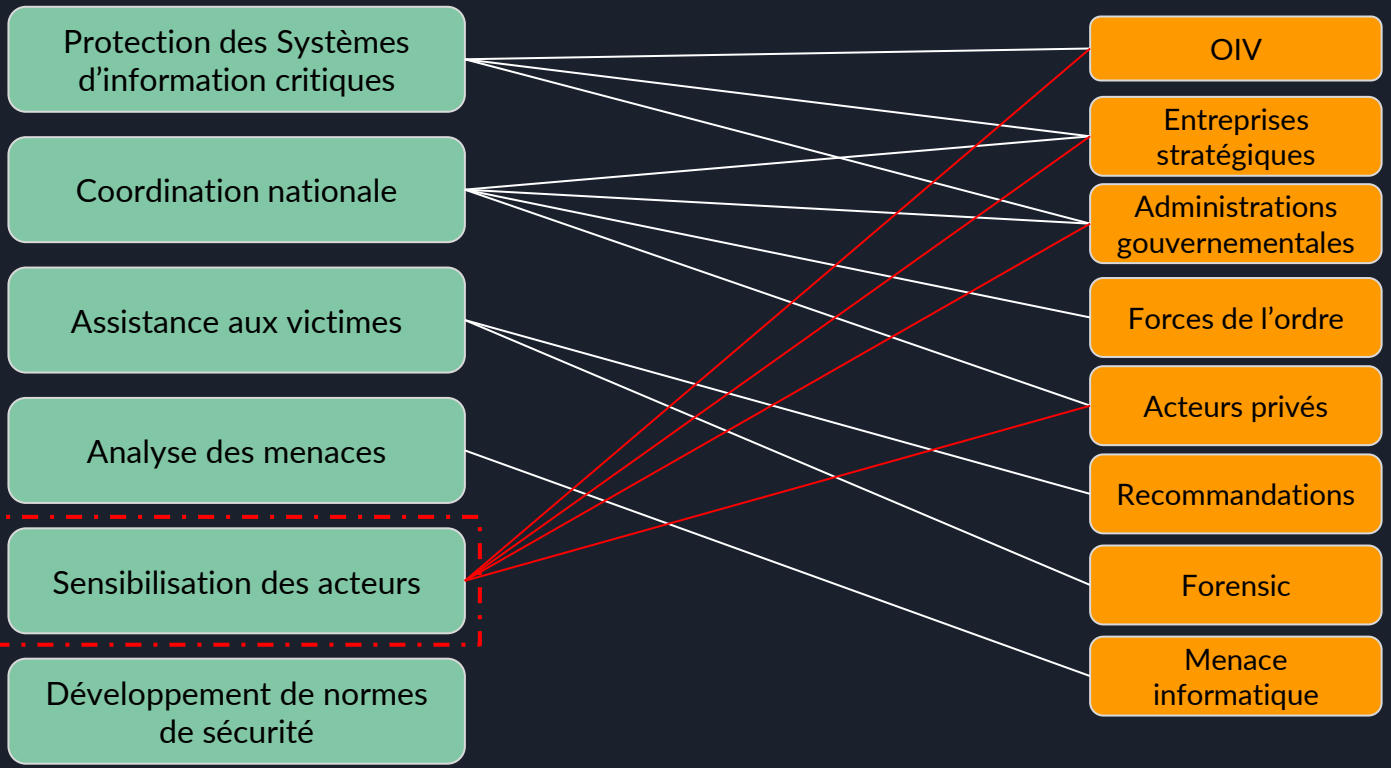
Objectifs de la gestion des incidents de sécurité par l'ANSSI



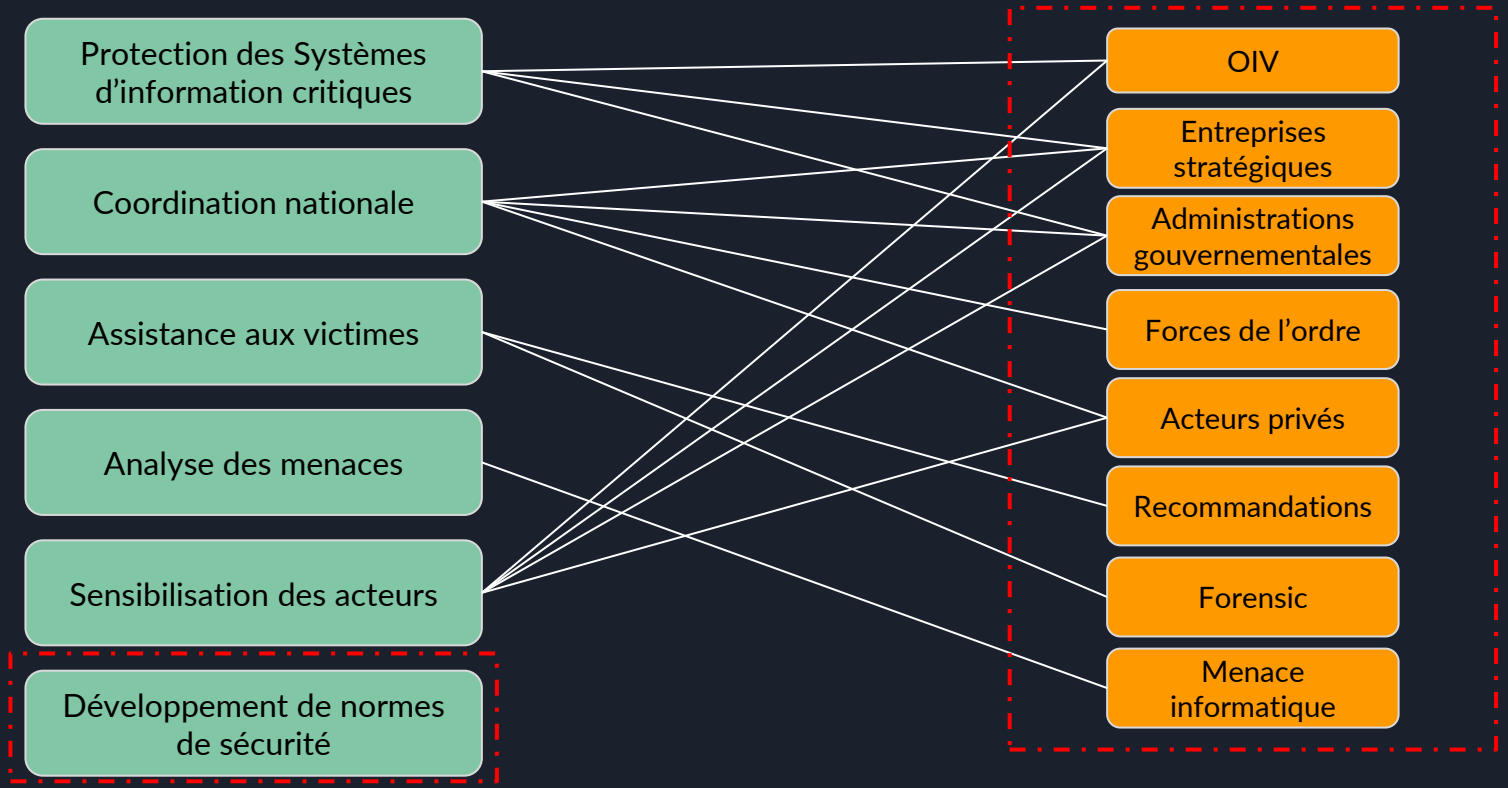
Objectifs de la gestion des incidents de sécurité par l'ANSSI



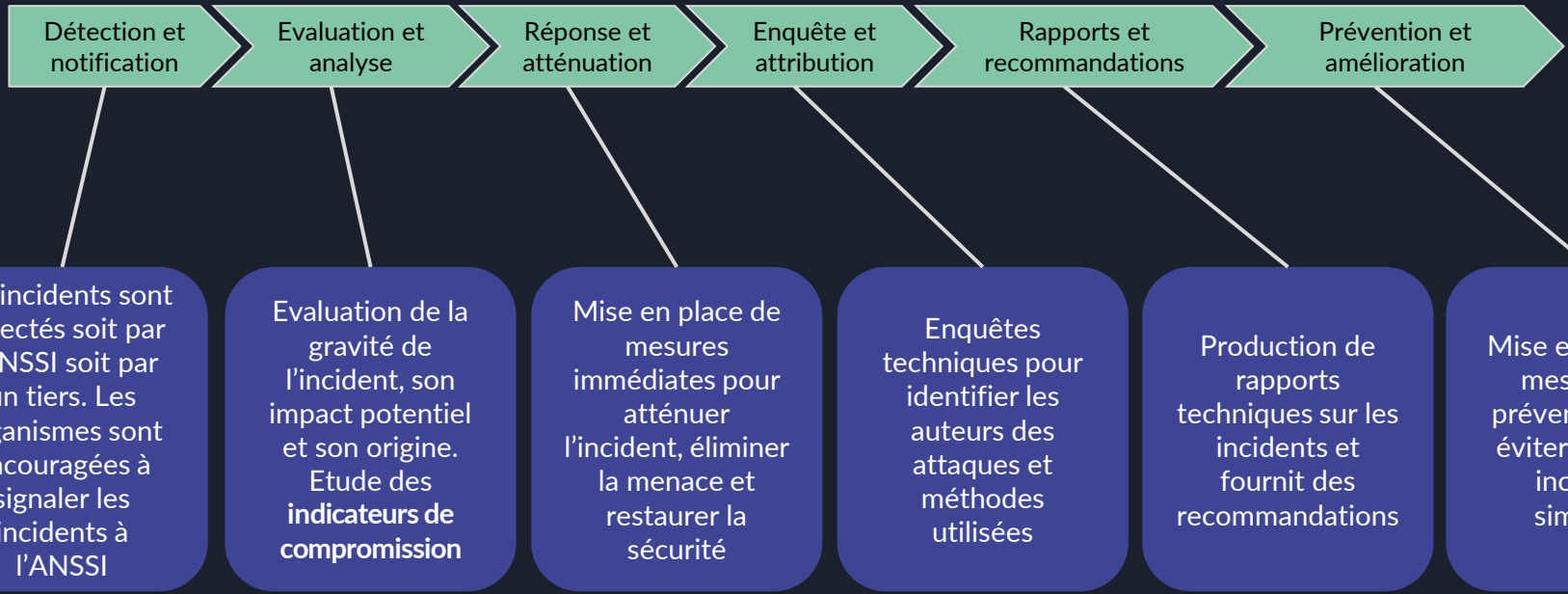
Objectifs de la gestion des incidents de sécurité par l'ANSSI



Objectifs de la gestion des incidents de sécurité par l'ANSSI



Les processus de gestion des Incidents de Sécurité



Conclusion

ISO 31000:2018

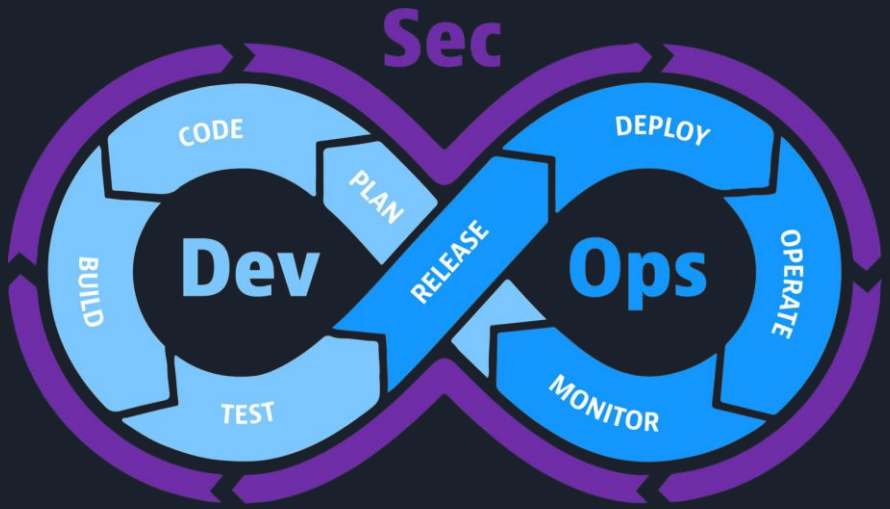
Recommandations de l'ANSSI

COSO ERM (Enterprise Risk Management)

Cours 6 : Conception de Systèmes conformes aux normes

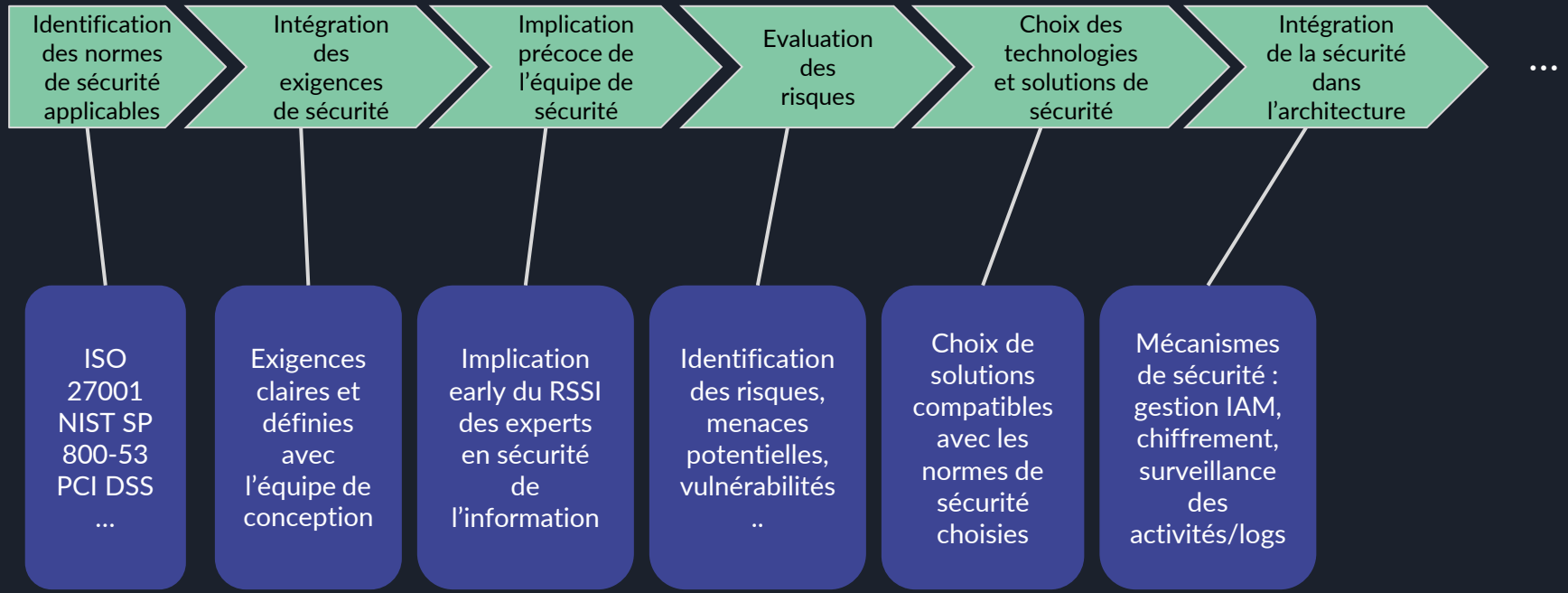
Intégration des normes dès la phase de conception

L'intégration des normes de sécurité dès la phase de conception d'un projet informatique est une pratique essentielle pour garantir que les systèmes informatiques sont conçus avec la sécurité en tête.

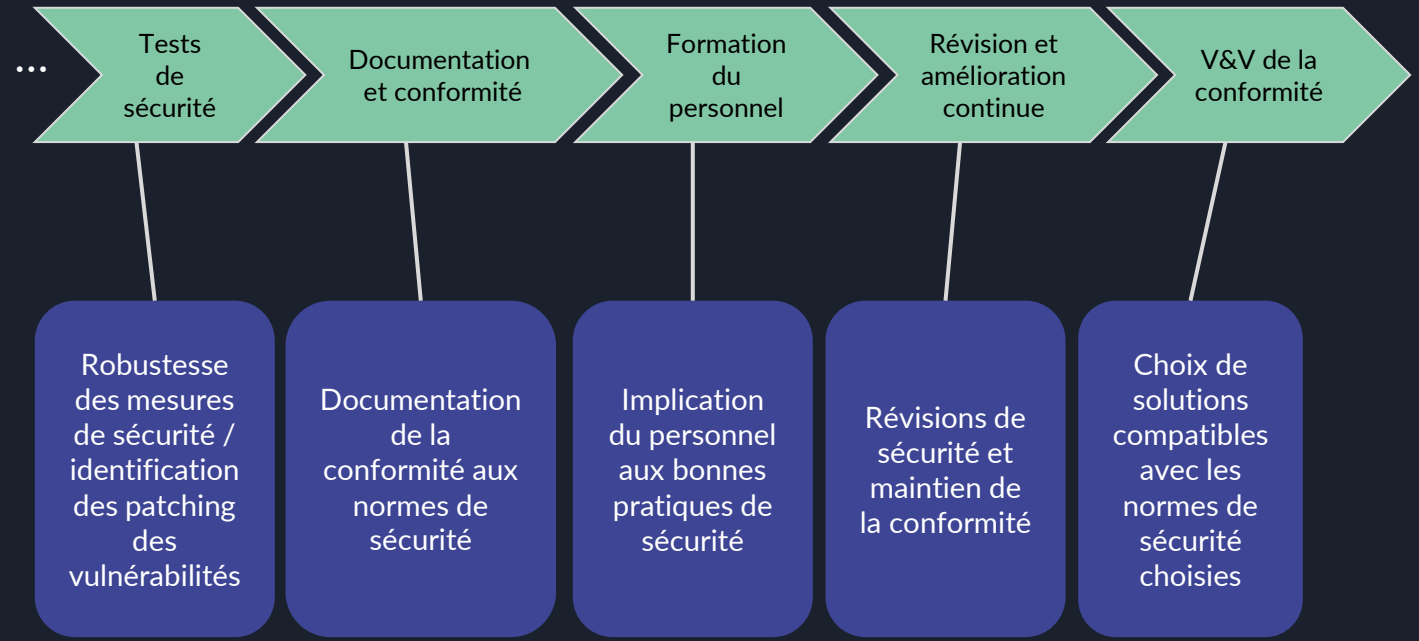


Le DevSecOps, nouvelle méthodologie de conception

Les processus de gestion des Incidents de Sécurité (partie 1)



Les processus de gestion des Incidents de Sécurité (partie 2)



Relation entre Validation et Vérification

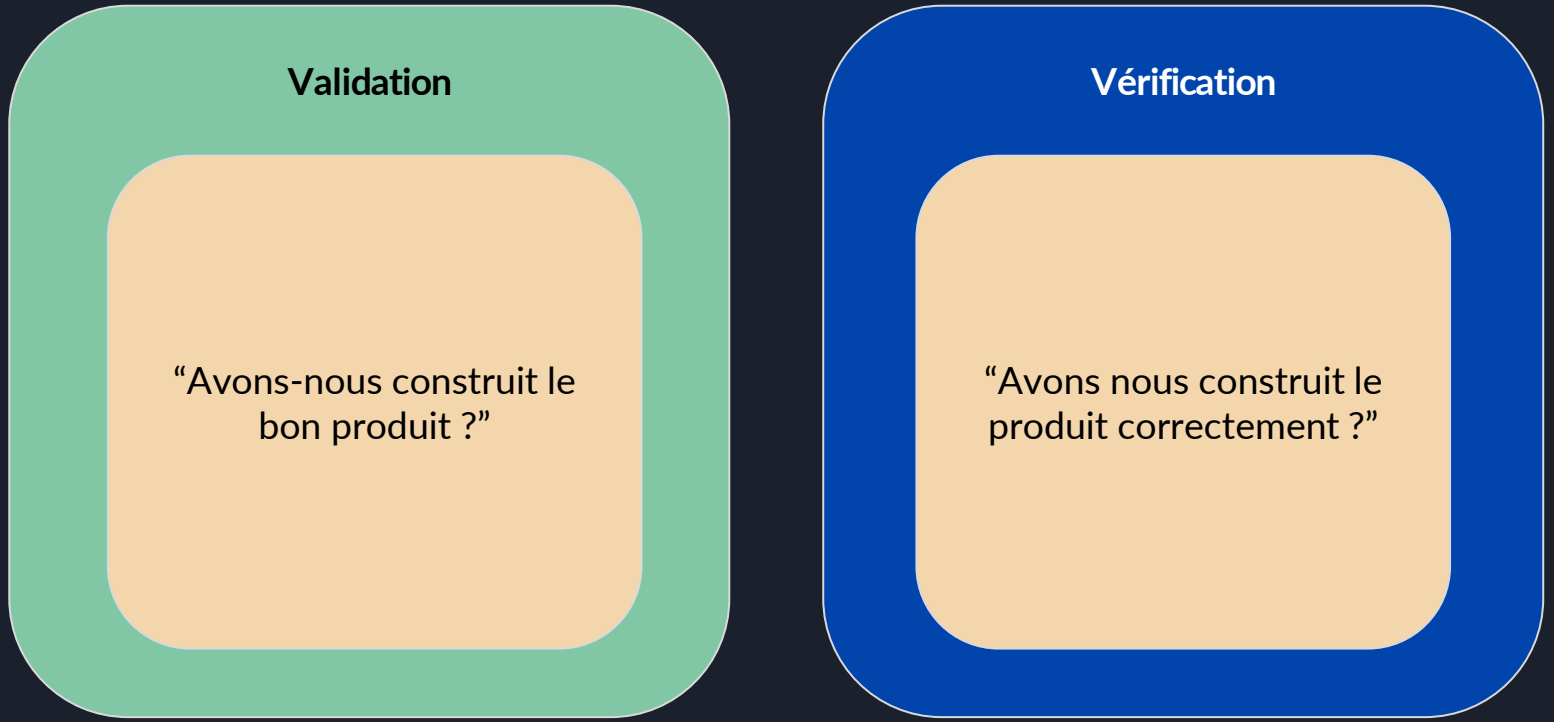
Validation

La validation est généralement effectuée en fin de projet ou de développement pour s'assurer que le produit final répond au besoin client

Vérification

La vérification est effectuée tout au long du processus de développement ou de production pour garantir que chaque étape est correctement exécutée

Relation entre Validation et Vérification



Étapes de la Validation et Vérification

Validation

Tests et vérifications approfondies

Tests de performance
Tests de conformité
Tests fonctionnels…

Vérification

Activités de contrôle qualité

Inspection
Audit
Revue de code
Surveillance des processus

Résultats attendus de la Validation et Vérification

Validation

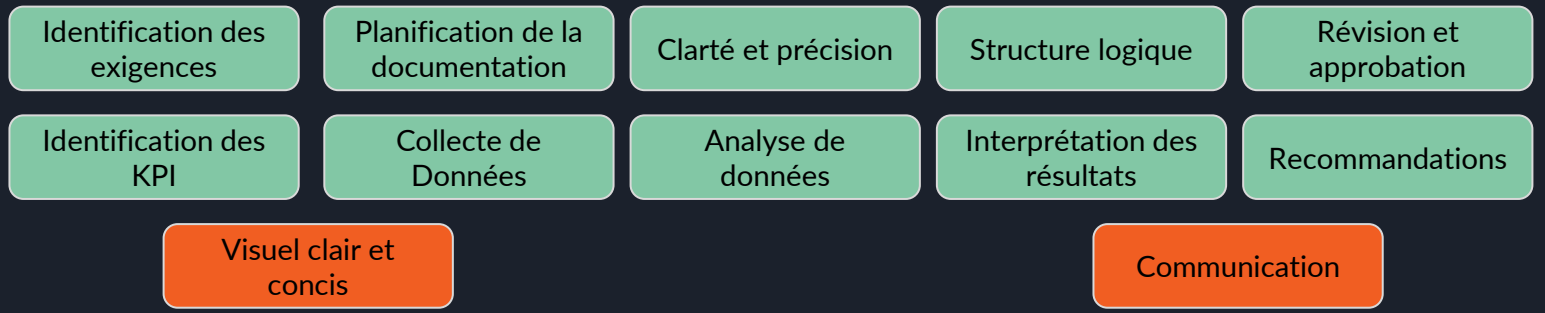
Le produit ou le système est conforme aux exigences établies et est prêt à être mis en service ou à être utilisé

Vérification

Chaque étape du processus a été exécutée correctement et les produits intermédiaires sont conformes aux normes et réglementations.

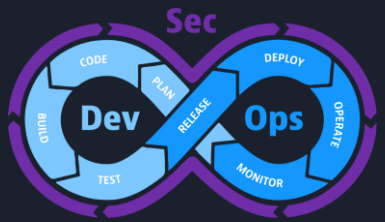
Documentation et rapports de conformité

La création d'une bonne documentation et de rapports de conformité est essentielle pour garantir que les processus, les produits ou les systèmes respectent les normes, les réglementations et les spécifications établies.



Etude de cas :
Présentation des méthodologies

Groupe 1



DevSecOps

Groupe 2



Threat Modeling

Groupe 3



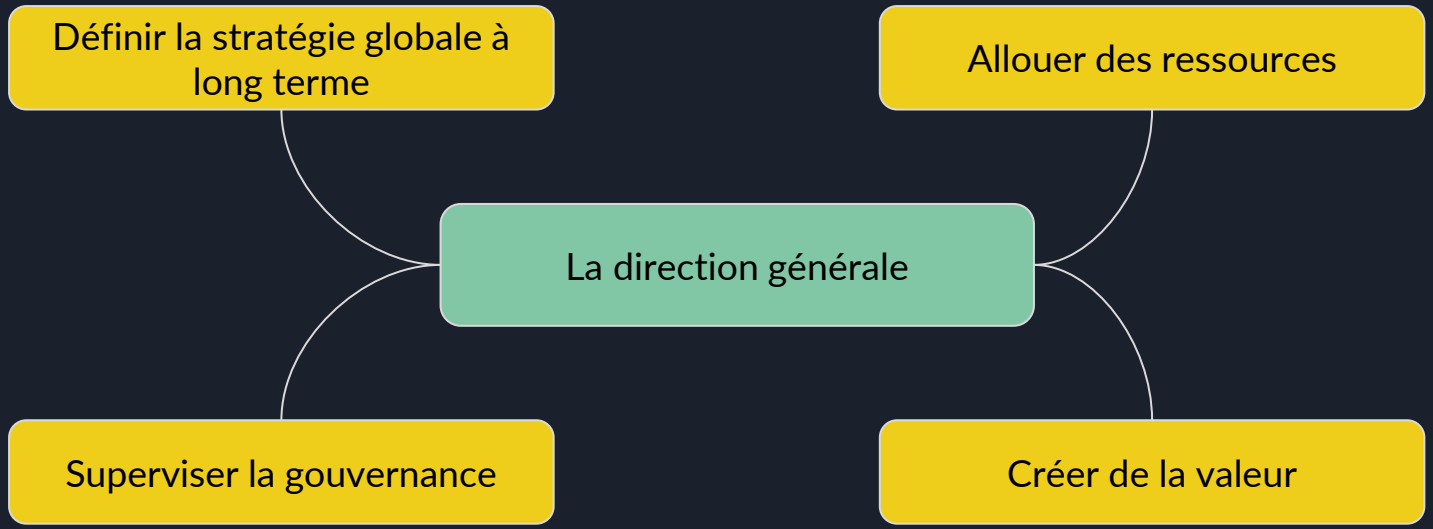
Secure Coding Standards

Cours 7 : Gouvernance IT

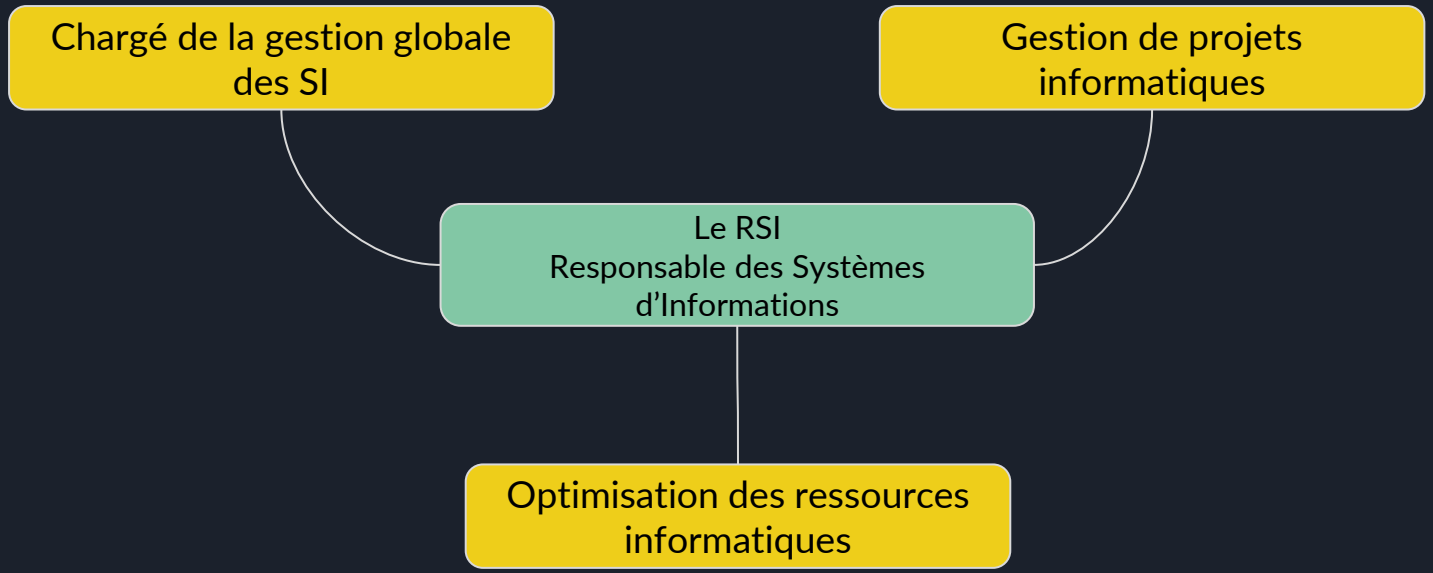
Sommaire du cours
Les SI dans la stratégie d’entreprise et la gouvernance

Rôles et responsabilités des acteurs des SI
Management : Alignement sur la stratégie d’entreprise
Gouvernance des SI : Alignement stratégique
Alignement stratégique dans la gouvernance des SI
Gestion des risques des SI
Sécurité des systèmes d’information
Stockage des données et Data Manager
L’auditeur : Audit et évaluation des systèmes d’information
L’analyse de performance : exemple de KPIs

Rôles et responsabilités des SI



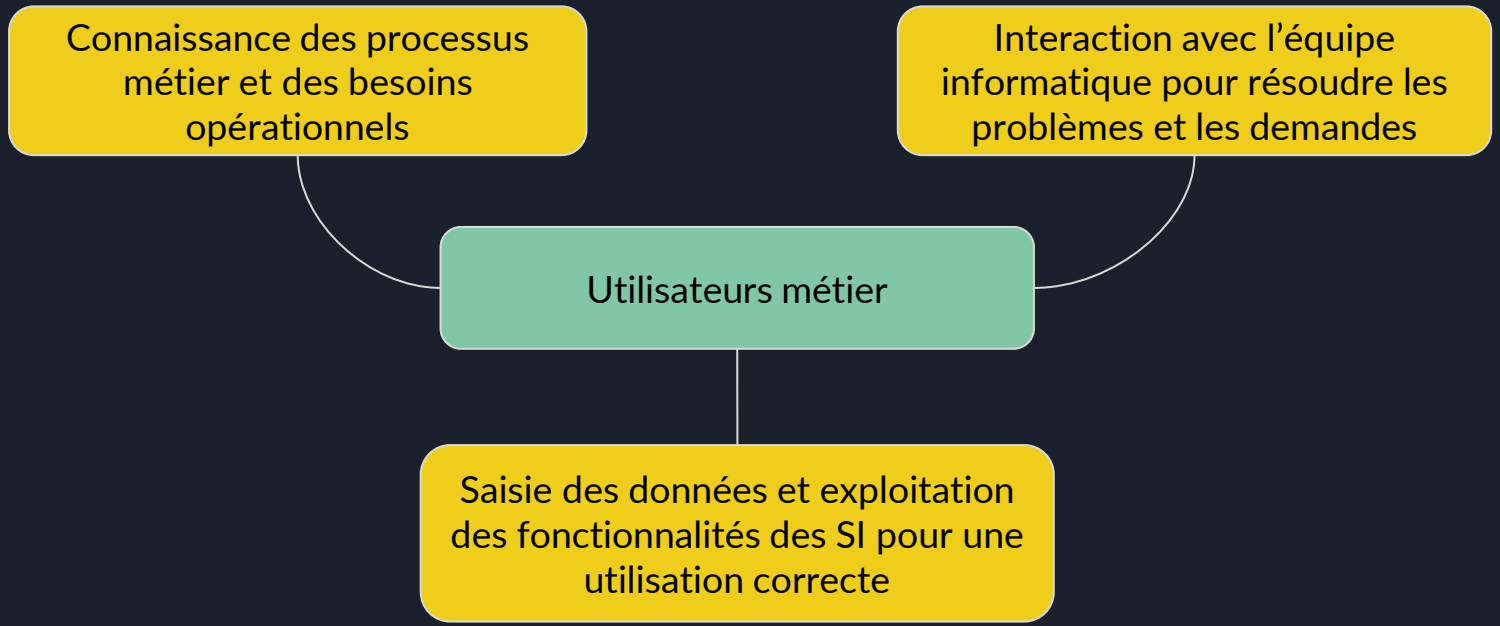
Rôles et responsabilités des SI



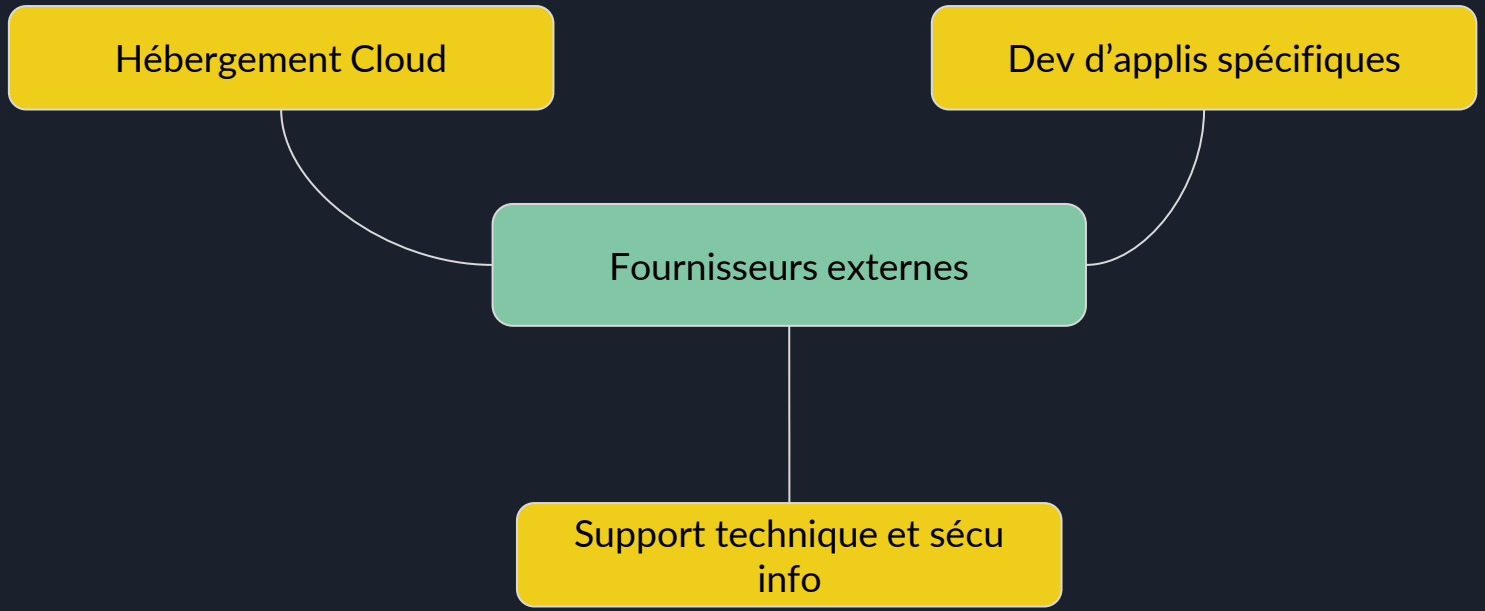
Rôles et responsabilités des SI



Rôles et responsabilités des SI



Rôles et responsabilités des SI



Management : Alignement sur la stratégie d’entreprise

Les systèmes d’informations doivent être alignés sur la stratégie globale de l’entreprise pour maximiser leurs valeurs.

- Identification des objectifs stratégiques de l’entreprise
- Intégration des SI dans les processus métiers
- Communication/Collaboration avec les parties prenantes

Management : Alignement sur la stratégie d’entreprise

Identification des objectifs stratégiques de l’entreprise

Identifier les objectifs stratégiques afin de trouver comment les systèmes d’information peuvent les soutenirs (Processus, Méthodes, Outils)

Déterminer les investissements nécessaires pour tendre vers les objectifs visés.

Management : Alignement sur la stratégie d’entreprise

Intégration des SI dans les processus métiers

Intégrer les SI dans les processus métiers pour les accompagner et faciliter leur travail.

Rationaliser les processus de travail et éviter les pertes de temps et la qualité des données.

Management : Alignement sur la stratégie d’entreprise

Communication/Collaboration avec les parties prenantes

Identifier plus rapidement les exigences des SI pour le besoin opérationnel

S’assurer que les SI respectent la conformité aux normes et réglementations.

Alignement stratégique dans la gouvernance des SI

Comprendre les besoins de l'entreprise	Définitions des contributions	Cohérence avec les priorités
La compréhension claire des objectifs et des besoins de l'entreprise permet de bien définir sa roadmap et sa stratégie.	La réalisation des objectifs de l'entreprise passe par une gouvernance et des contributions clairement définies	Pour garantir l'alignement stratégique, les investissements technologiques doivent être cohérents avec les priorités de l'entreprise.

Gestion des risques des SI

Identification des risques	Evaluation des risques	Gestion des risques
L'identification des risques liés aux SI est le premier pas pour une gestion efficace des SI	L'évaluation des risques informatiques permet de déterminer leur gravité et de prioriser les actions de gestion des risques	Vise à réduire les vulnérabilités des SI et à garantir la continuité des opérations. Elle inclut également des mécanismes de contrôle et de surveillance pour détecter et prévenir les risques potentiels

L’auditeur : Audit et évaluation des systèmes d'information

Identifier les forces et les faiblesses des SI

Evaluer la performance des systèmes d’information

Vérifier la conformité

Proposer des améliorations et des solutions

Etude de cas finale :
Cartographie des normes, standards et lois dans l’informatique

En utilisant toutes les informations présentes dans les cours. Établissez une cartographie complète des différents textes et correspondant aux normes, standards et lois présentes dans le domaine de l’informatique.

La cartographie devra être la plus complète possible afin de pouvoir avoir une vision étendue des différents domaines abordés en cours.